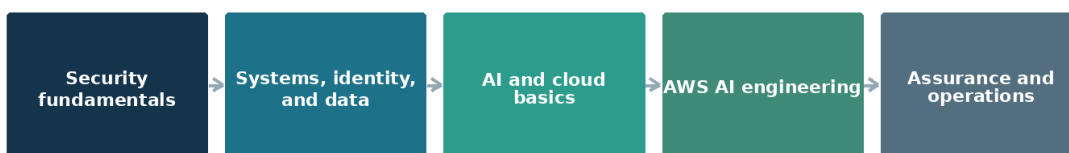


MANUAL PRÁTICO DE ENGENHARIA DE SEGURANÇA

Protegendo a IA empresarial na Amazon Web Services

Um guia prático para Amazon Bedrock, SageMaker AI, IAM, Macie, Security Hub, OpenAI, Claude, RAG, MCP, Agentes, Governança e Resposta a Incidentes.

A practical learning path



Each stage adds capability without removing the controls learned earlier.

O manual começa com os fundamentos e avança em direção à operação segura da empresa.

Alberto (AI) Leiva

Versão 1.0 — Julho de 2026

Sobre este manual

Este manual explica como projetar, construir, proteger, governar, testar e operar sistemas de IA empresariais. Ele começa com os fundamentos de segurança, sistemas, identidade, dados, IA e nuvem. Em seguida, aborda a Amazon Web Services e os serviços comumente usados para IA empresarial. O objetivo é proporcionar uma compreensão prática: saber o que cada componente faz, onde a confiança muda, quais controles são importantes, como testá-los e quais evidências demonstram sua eficácia.

RECURSO EDUCACIONAL INDEPENDENTE

Esta publicação não constitui orientação oficial da Microsoft, OpenAI, Anthropic, OWASP, NIST, MITRE, ISO ou de qualquer órgão regulador. As funcionalidades dos produtos, leis, normas e licenciamentos estão sujeitos a alterações. Consulte fontes oficiais atualizadas e profissionais qualificados para tomar decisões importantes.

Práticas Seguras e Autorizadas

Utilize os exercícios apenas em ambientes que você controla ou para os quais você tem autorização explícita para testar. Confirme o escopo, as contas, os destinos, os dados, o tráfego esperado, os limites de custo, as comunicações, as condições de parada e a limpeza antes de realizar os testes.

- Utilize dados sintéticos ou de baixo risco sempre que possível.
- Não teste sistemas públicos, de terceiros, de clientes ou de produção sem autorização por escrito.
- Não tente obter segredos, informações pessoais ou acesso além do objetivo aprovado.
- Interrompa o exercício quando ele afetar um sistema, pessoa ou conjunto de dados não intencional.
- Proteja os resultados e as evidências dos testes, pois eles podem conter detalhes sensíveis.

REGRA FUNDAMENTAL

Habilidade técnica não cria permissão.

Como usar o manual

Leia os capítulos introdutórios na ordem indicada. Os capítulos posteriores podem ser usados como referência, mas cada um pressupõe que o leitor compreenda os conceitos de identidade, fluxo de dados, autorização, risco e o ciclo de vida do sistema de IA. Conclua o breve exercício prático ao final de cada capítulo e guarde as evidências que você gerar.

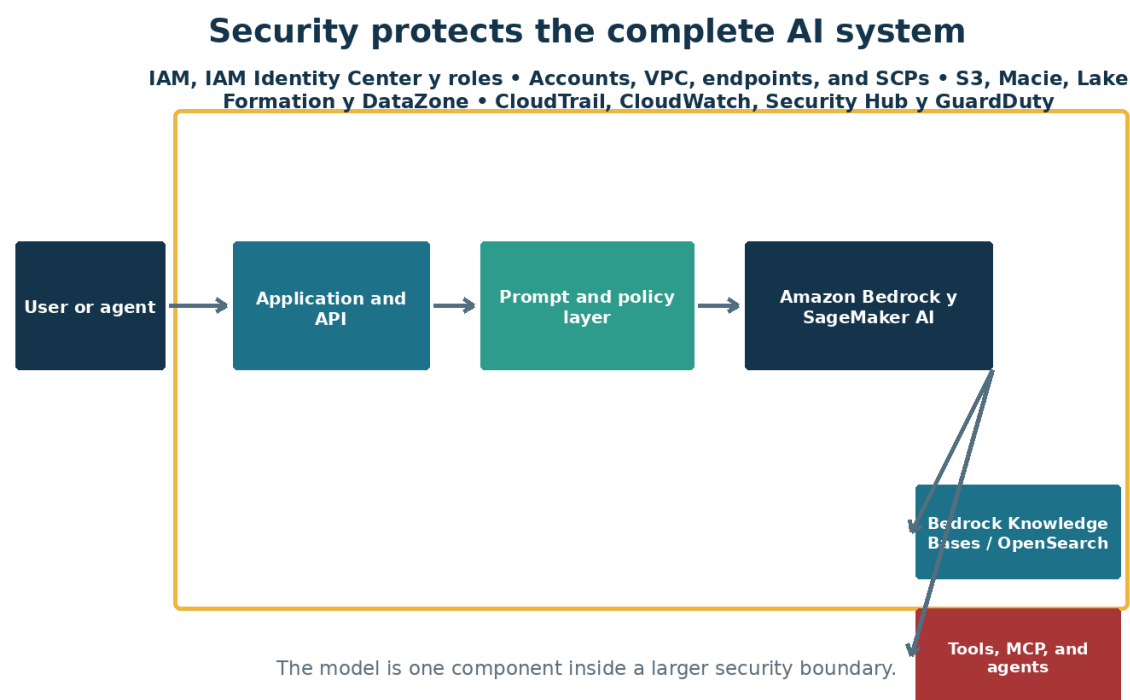


Figura 1. Um modelo opera dentro de um sistema de aplicação, identidade, dados, ferramentas e governança.

Índice

Capítulos 1–14	Página	Capítulos 15–28	Página
1. Fundamentos de Engenharia de Segurança	7	15. Segurança de Identidade e Identidades Não Humanas	44
2. Sistemas, Redes, Identidade e Noções Básicas de Dados	10	16. Âmbito de aplicação, governança de dados, privacidade e IA paralela	47
3. Inteligência Artificial, Aprendizado de Máquina e Modelos de Linguagem	13	17. Infraestrutura, Rede, Segredos e Proteção de API	50
4. Fundamentos de Serviços em Nuvem e IA	16	18. Riscos da OWASP para LLMs, Agentes, NHIs, APIs e Aplicações Web	52
5. Como funcionam os sistemas de IA empresariais	19	19. Cadeia de Suprimentos de IA, Desenvolvimento Seguro e LLMOps	55
6. Fundamentos do Azure para Segurança de IA	22	20. Avaliação, Red Teaming e Testes de Segurança	57
7. Confiança Zero e Defesa em Profundidade para IA	24	21. Registro, Detecção, Investigação e Resposta a Incidentes	60
8. Modelagem de Ameaças em IA e Sistemas Agentes	27	22. Confiabilidade, Resiliência, Desempenho e FinOps	63
9. Microsoft Foundry: Projetos, Modelos e Controles	30	23. IA Responsável, Supervisão Humana e Mudança Organizacional	65
10. OpenAI, Claude e opções de provedores de modelos	32	24. Considerações Legais, Regulatórias, de Propriedade Intelectual e de Registros	68
11. Instrução, Contexto, Memória e Segurança do Conteúdo	34	25. Estruturas: NIST, ISO, MITRE e Mapeamento de Controles	71
12. Geração Aumentada de Recuperação Segura	36	26. Construindo um Programa de Governança e Garantia de IA	73
13. Agentes, Ferramentas, MCP e Comunicação entre Agentes	39	27. Laboratórios de Engenharia de Segurança Guiada	76
14. Copilotos e IA para Produtividade Empresarial	41	28. Projeto Final: Agente de Conhecimento Empresarial Seguro	78
Apêndices — listas de verificação, modelos, glossário e fontes oficiais			80

Os títulos dos capítulos são clicáveis no Microsoft Word.

Roteiro de Aprendizagem

A sequência parte dos princípios básicos até uma implementação empresarial completa. Cada parte agrega capacidade e responsabilidade.

Parte I — Fundamentos— Compreenda o sistema antes de escolher os controles.

Parte II — Construindo IA na AWS— Crie serviços de IA úteis com limites seguros desde o início.

Parte III — Protegendo Sistemas de IA— Aplicar defesas de identidade, dados, aplicativos, modelos e infraestrutura.

Parte IV — Governança e Operações— Utilize a IA de forma responsável, avalie os riscos e preserve as evidências.

Parte V — Laboratórios Práticos— Transformar conceitos em prática de engenharia repetível.

O que o leitor será capaz de fazer

- Explique uma arquitetura de IA empresarial e identifique seus limites de confiança.
- Utilize controles de identidade, rede, dados, aplicativos, modelos e governança em conjunto.
- Crie fluxos de trabalho RAG e de agentes delimitados que reconheçam as permissões.
- Aplique as diretrizes do OWASP LLM, agentic, NHI, API e web.
- Avalie a qualidade, a segurança, a proteção, a privacidade, a confiabilidade e o custo.
- Coletar evidências, responder a incidentes e mapear os controles para as principais estruturas.

PARTE I — FUNDAMENTOS

Entenda o sistema antes de escolher os controles.

COMPREENDER • APLICAR • TESTAR • COMPROVAR

Capítulo 1 — Fundamentos da Engenharia de Segurança

Aprenda a linguagem, os hábitos e os princípios fundamentais usados para proteger qualquer sistema antes de aplicá-los à IA ou à AWS.

O que um engenheiro de segurança protege

Um engenheiro de segurança ajuda a organização a usar a tecnologia, mantendo os riscos dentro de limites aceitáveis. Seu trabalho não é rejeitar todas as mudanças, mas sim entender os objetivos da organização, identificar possíveis falhas ou abusos, implementar medidas de segurança práticas e tornar os riscos remanescentes visíveis para a pessoa autorizada a aceitá-los.

- **Confidencialidade:** as informações estão disponíveis apenas para pessoas e sistemas autorizados.
- **Integridade:** as informações, o software e as decisões são precisos e protegidos contra alterações não autorizadas.
- **Disponibilidade:** os serviços e as informações podem ser utilizados quando necessário.
- **Privacidade:** as informações pessoais são tratadas de forma lícita e respeitosa.
- **Segurança:** a tecnologia não causa danos inaceitáveis às pessoas ou ao meio ambiente.
- **Responsabilidade:** ações importantes podem ser rastreadas até uma identidade responsável.

Risco em linguagem simples

Risco é a possibilidade de uma ameaça explorar uma vulnerabilidade e causar danos. Comece analisando o impacto no ativo e no negócio, em vez de focar em uma funcionalidade específica do produto. Descreva o cenário com clareza: quem ou o que poderia agir, qual vulnerabilidade poderia ser explorada, o que poderia acontecer, qual a probabilidade disso ocorrer e quais controles reduzem o risco.

- **Ativo:** algo valioso que precisa de proteção.
- **Ameaça:** uma pessoa, evento, condição ou capacidade que pode causar danos.
- **Vulnerabilidade:** uma fraqueza que pode ser explorada ou acionada.
- **Controle:** uma salvaguarda que altera a probabilidade ou o impacto.
- **Risco residual:** o risco que permanece após os controles.
- **Responsável pelo risco:** a pessoa responsável pelo resultado do negócio.

Tipos de controle e evidências

Os controles preventivos tentam impedir um evento. Os controles detectivos revelam que ele ocorreu ou está em desenvolvimento. Os controles reativos o contêm e o corrigem. Os controles de recuperação restauram a operação segura. Uma política escrita não comprova que um controle técnico funciona. As evidências podem incluir exportações de configuração, logs, aprovações, chamados, resultados de testes, capturas de tela, revisão de código e exercícios de incidentes.

- Dê preferência a controles que sejam repetíveis e mensuráveis.
- Não confie apenas em treinamento quando uma medida de segurança técnica for viável.

- Teste que controla o trabalho em condições realistas.
- Registre exceções, proprietários, datas de vencimento e controles compensatórios.
- Preserve as evidências em um local protegido e passível de busca.

Um método de engenharia repetível

Utilize o mesmo método básico para cada revisão: compreenda a finalidade, inventarie os ativos e as dependências, mapeie os dados e os limites de confiança, identifique as ameaças e os modos de falha, selecione os controles, teste-os, documente o risco residual, monitore a operação e promova melhorias após mudanças ou incidentes.

- Faça perguntas simples até que a arquitetura fique clara.
- Verificar as suposições com a configuração e os registros.
- Separe fato, inferência e opinião.
- Aumentar a incerteza quando o impacto potencial for elevado.
- Nunca teste um sistema sem permissão e um escopo acordado.

UM CONTROLE QUE EXISTE APENAS NO PAPEL

Uma política exige que a atividade do administrador seja registrada, mas o serviço de registro em nuvem está desativado em uma das assinaturas. A política descreve a intenção; a configuração e um teste bem-sucedido fornecem evidências.

Exercício: Elabore uma declaração de risco básica.

- Escolha um ativo comercial comum, como um repositório de arquivos de clientes.
- Identifique uma ameaça, uma vulnerabilidade e um impacto plausível.
- Descreva o risco como uma breve relação de causa e efeito.
- Selecione um controle preventivo, detetivo, reativo e de recuperação.
- Indique as evidências que demonstrariam a eficácia de cada controle.

Verificação de controle do capítulo

- ☐ Confidencialidade, integridade, disponibilidade, privacidade, segurança e responsabilidade são levadas em consideração.
- ☐ Os riscos são descritos como cenários plausíveis.
- ☐ Os controles abrangem prevenção, detecção, resposta e recuperação.
- ☐ As evidências de controle são identificadas e mantidas.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 2 — Sistemas, Redes, Identidade e Noções Básicas de Dados

Compreenda os componentes técnicos básicos que os serviços de IA herdam de aplicativos comuns e sistemas em nuvem.

Aplicações e APIs

Normalmente, uma aplicação possui uma interface de usuário, lógica de negócios, armazenamento de dados e conexões com outros serviços. APIs permitem que os sistemas troquem solicitações e resultados. A IA não remove essas camadas; ela adiciona um modelo e novas formas de entrada, saída e incerteza. As fragilidades comuns das aplicações ainda são relevantes.

- Validar entrada e codificar saída
- Autenticar o chamador e autorizar a ação solicitada.
- Utilize um meio de transporte seguro, como o TLS.
- Limitar a taxa de solicitações e controlar o consumo de recursos.
- Lidar com erros sem expor segredos ou detalhes internos.
- Mantenha as dependências atualizadas e inventariadas.

Conceitos de rede

Toda conexão tem uma origem, um destino, um protocolo, uma porta, uma direção e uma finalidade. Pontos de extremidade públicos podem ser acessados pela internet; pontos de extremidade privados mantêm o tráfego em redes controladas. Firewalls, gateways, proxies, DNS, segmentação e controles de saída limitam quais sistemas podem se comunicar.

- Documentar fluxos de entrada e saída
- Negar caminhos desnecessários
- Desenvolvimento, teste e produção separados.
- Inspeccionar e registrar pontos de controle importantes
- Proteja as interfaces administrativas com mais robustez.
- Planeje o gerenciamento de DNS e certificados com antecedência.

Gestão de identidade e acesso

A autenticação comprova uma identidade. A autorização determina o que essa identidade pode fazer. Usuários humanos, aplicativos, automação, contas de serviço e agentes de IA precisam de identidades. Funções e permissões devem refletir as necessidades do trabalho ou da tarefa, e o acesso privilegiado deve ser temporário e revisado.

- Use autenticação multifatorial para pessoas
- Prefira tokens de curta duração a senhas ou chaves armazenadas.
- Aplicar o princípio do menor privilégio e da segregação de funções.

- Remova o acesso imediatamente quando a finalidade ou a propriedade terminar.
- Analisar identidades privilegiadas e inativas
- Registre as decisões de acesso bem-sucedidas e malsucedidas.

Ciclo de vida dos dados

Os dados são criados ou coletados, classificados, usados, compartilhados, armazenados, copiados, retidos, arquivados e excluídos. A segurança deve abranger todo o ciclo de vida e cada cópia derivada. A IA cria derivados adicionais, como fragmentos, incorporações, índices, prompts, saídas, conjuntos de dados de avaliação e registros.

- Recolha apenas o necessário.
- Fonte do registro, proprietário, classificação, finalidade e uso permitido.
- Criptografe dados confidenciais em repouso e em trânsito.
- Restringir o acesso de acordo com a finalidade.
- Defina regras de retenção e exclusão.
- Confirme se os backups, índices e dados derivados atendem aos requisitos de exclusão.

O MODELO SEGURO POR TRÁS DE UMA API INSEGURA

Um endpoint de modelo é privado, mas a API pública do aplicativo aceita qualquer identificador de documento sem verificar se o usuário autenticado pode acessar esse documento. O modelo é protegido; os dados comerciais não são.

Exercício: Rastreie uma requisição web simples.

- Desenhe um usuário, um navegador, uma API de aplicativo, um provedor de identidade, um banco de dados e um serviço de registro de logs.
- Identifique cada conexão de rede e limite de confiança.
- Descreva a autenticação e a autorização em cada etapa.
- Indique onde existem ou são copiados dados sensíveis.
- Adicione uma fonte de controle e uma fonte de evidência para cada limite.

Verificação de controle do capítulo

- ☐ Os controles de aplicativos e APIs continuam fazendo parte da segurança da IA.
- ☐ Os caminhos de rede e os limites de confiança são documentados.
- ☐ Autenticação e autorização são tratadas separadamente.
- ☐ O ciclo de vida dos dados inclui cópias derivadas e exclusão.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima

revisão.

Capítulo 3 — Inteligência Artificial, Aprendizado de Máquina e Modelos de Linguagem

Compreender os conceitos essenciais de IA suficientemente bem para identificar suposições de segurança, limitações e testes relevantes.

IA, aprendizado de máquina e IA generativa

Inteligência artificial é um termo amplo para sistemas que executam tarefas associadas ao raciocínio, percepção, previsão ou linguagem. O aprendizado de máquina encontra padrões em dados, em vez de depender apenas de regras preestabelecidas. A IA generativa produz novos textos, imagens, áudios, vídeos ou códigos com base em padrões aprendidos durante o treinamento.

- Um modelo é um sistema matemático aprendido — não um banco de dados de fatos garantidos.
- O treinamento cria ou ajusta um modelo a partir de dados.
- A inferência utiliza um modelo treinado para produzir um resultado.
- O ajuste fino altera o comportamento do modelo com exemplos adicionais.
- A RAG fornece informações externas selecionadas sob demanda, sem a necessidade de retreinar o modelo.

Como um modelo de linguagem lida com o texto

Um modelo de linguagem processa tokens, que são fragmentos de texto e não necessariamente palavras completas. A janela de contexto contém as instruções e informações disponíveis para a resposta atual. O modelo prevê continuações úteis com base em padrões e instruções; ele não verifica a veracidade a menos que o sistema circundante forneça fontes e verificações confiáveis.

- Prompt: informações ou instruções fornecidas a um modelo
- Instruções do sistema: orientações de alta prioridade fornecidas pelo aplicativo.
- Token: uma unidade usada para processar entrada e saída.
- Janela de contexto: o espaço de trabalho limitado para a solicitação.
- Temperatura e configurações relacionadas: controles que podem influenciar a variação da saída.
- Alucinação: conteúdo que aparenta confiança, mas que não possui fundamento ou é incorreto.

Incorporações e similaridade

Um embedding representa o conteúdo como números, permitindo que um sistema compare significados ou similaridades. Os embeddings suportam busca semântica e RAG (Random Access Groups - Gráficos de Referência Aleatória). São dados derivados e ainda podem revelar informações sobre a fonte. Um banco de dados vetorial armazena e pesquisa essas representações juntamente com identificadores e metadados.

- Proteja os dados incorporados de acordo com a sensibilidade da fonte.
- Use metadados para preservar a propriedade e as permissões.

- Avalie se resultados semelhantes são realmente relevantes.
- Remova os elementos incorporados quando a fonte precisar ser excluída.
- Não considere a similaridade semântica como prova ou autorização.

O que os modelos podem e não podem fazer

Os modelos podem resumir, classificar, transformar, elaborar, extrair, raciocinar e invocar ferramentas quando conectados por uma aplicação. No entanto, também podem interpretar o contexto incorretamente, seguir instruções maliciosas, expor informações, produzir conteúdo tendencioso ou inseguro e agir com autoridade excessiva. A arquitetura subjacente deve conter essas limitações.

- Utilize critérios de aceitação mensuráveis.
- Verifique as fontes para obter respostas relevantes.
- Mantenha as regras de negócio determinísticas fora do modelo.
- Exigir julgamento humano para decisões de alto impacto
- Monitore o comportamento após a implantação, pois o uso e os ataques mudam.

Fluente é confundido com correto.

Um assistente produz uma resposta jurídica segura com uma citação de aparência realista. A citação não existe. A falha ocorre porque o fluxo de trabalho recompensa a conclusão fluente sem recuperação, validação de citação ou revisão humana.

Prática: Observe a variabilidade do modelo

- Faça a mesma pergunta inofensiva várias vezes a uma modelo aprovada.
- Registre as diferenças nos fatos, na redação, na incerteza e nas fontes.
- Adicione um contexto confiável e repita o exercício.
- Defina um teste que distinga uma resposta fundamentada de uma resposta fluente.
- Liste as decisões que nunca devem se basear apenas em texto gerado.

Verificação de controle do capítulo

- ☐ Distinguem-se os processos de treinamento, inferência, ajuste fino e RAG (Gerador Aleatório de Aleatoriedade).
- ☐ Os limites de tokens e contexto são compreendidos.
- ☐ Os embeddings são tratados como dados derivados protegidos.
- ☐ A fluência nunca é considerada prova de correção.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 4 — Fundamentos de Serviços em Nuvem e IA

Entenda como os serviços de nuvem compartilhados, as opções de implantação e o ciclo de vida da IA moldam a responsabilidade pela segurança antes de entrar na AWS.

Security follows the complete AI lifecycle

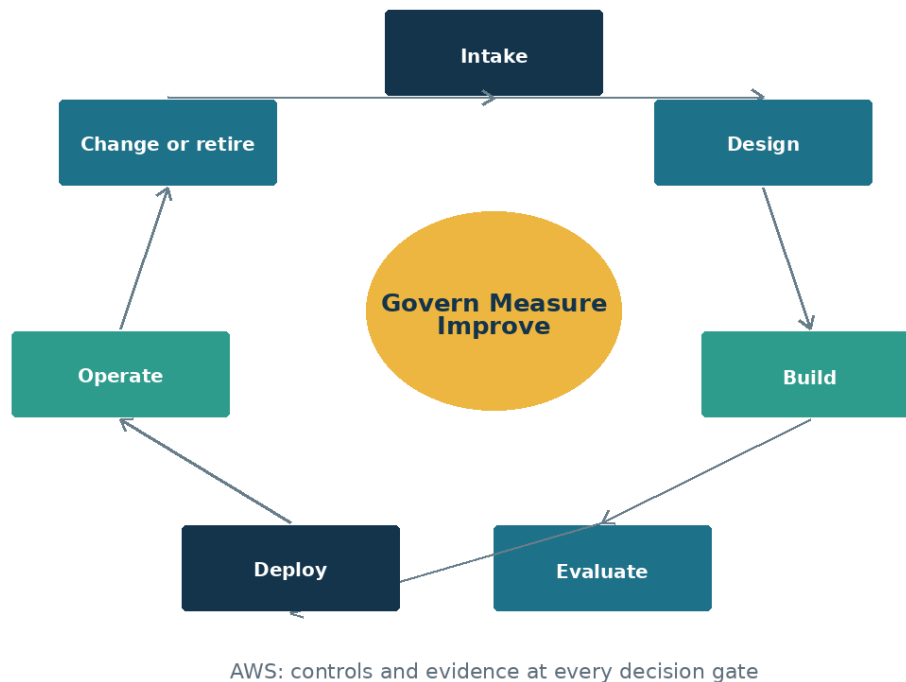


Figura 4. Segurança e governança acompanham o sistema desde a admissão até a aposentadoria.

Modelos de serviço em nuvem

Os serviços de infraestrutura fornecem computação, armazenamento e rede com maior controle para o cliente. Os serviços de plataforma gerenciam uma parcela maior do ambiente operacional. Os serviços de software fornecem uma aplicação completa. APIs de IA gerenciadas e plataformas de modelos reduzem o trabalho de infraestrutura, mas não eliminam a responsabilidade pela identidade, dados, configuração, lógica da aplicação, uso legal ou monitoramento.

- Documente o que o provedor protege e o que o cliente protege.
- Analisar a disponibilidade regional e o processamento de dados.
- Compreender o acesso administrativo e de suporte
- Confirme os compromissos de registro, backup, recuperação e nível de serviço.
- Planeje como cancelar ou substituir o serviço.

Regiões, inquilinos e limites de recursos

Um locatário representa uma identidade e um limite administrativo. Assinaturas e projetos organizam recursos, faturamento, políticas e acesso. Regiões afetam a latência, a resiliência, as obrigações legais e a disponibilidade de recursos. Defina esses limites antes que os dados entrem na plataforma.

- Mantenha a produção separada da experimentação.
- Selecione as regiões com base nos requisitos de negócios e de dados.
- Evite compartilhar credenciais entre locatários ou ambientes.
- Identifique os recursos com proprietário, finalidade, classificação, ambiente e data de expiração.
- Utilize políticas para impedir configurações não aprovadas.

Ciclo de vida do sistema de IA

Um sistema de IA passa pelas fases de ideação, captação de dados, projeto, preparação de dados, desenvolvimento, avaliação, aprovação, implantação, monitoramento, gestão de mudanças, resposta a incidentes e desativação. Segurança e governança devem acompanhar todo o ciclo de vida. Um controle adicionado somente na fase de implantação ignora dados inseguros e escolhas de projeto feitas anteriormente.

- Aprovar o caso de uso e os usos proibidos.
- Avaliar dados e risco do provedor
- Arquitetura de modelos de ameaças e uso indevido
- Avalie a qualidade, a segurança, a proteção, a privacidade e o custo.
- Monitore e teste novamente após a alteração.
- Desativar identidades, dados, índices, endpoints e contratos.

Da prova de conceito à produção

Uma prova de conceito responde à questão de se uma ideia pode funcionar. A produção também deve ser segura, confiável, sustentável, observável, acessível, estar em conformidade com as normas e ser recuperável. Utilize um processo de liberação com base em evidências, em vez de permitir que uma demonstração bem-sucedida se torne produção por acidente.

- Defina datas de validade para os experimentos.
- Use primeiro dados sintéticos ou de baixo risco.
- Acesso separado para desenvolvimento e produção
- Definir critérios de aceitação da produção
- Atribua a responsabilidade pelas operações e pela resposta a incidentes.

A DEMONSTRAÇÃO QUE SILENCIOSAMENTE SE TORNOU PRODUÇÃO

Um assistente piloto obtém usuários reais e dados sensíveis, mesmo utilizando a chave de API e o registro de testes do desenvolvedor. Nenhuma decisão formal marca a mudança, portanto, os controles de produção e a responsabilidade nunca chegam.

Exercício: Crie um portal de ciclo de vida de IA

- Liste cada etapa do ciclo de vida, da ideia à aposentadoria.
- Atribua um responsável a cada etapa.
- Defina as evidências de segurança e governança necessárias.
- Escolha condições claras de liberação e parada.
- Adicionar um processo de expiração e limpeza para experimentos.

Verificação de controle do capítulo

- ☐ A responsabilidade compartilhada na nuvem está documentada.
- ☐ Os limites relativos a inquilinos, regiões, ambientes e recursos são intencionais.
- ☐ A segurança acompanha todo o ciclo de vida da IA.
- ☐ A produção requer evidências explícitas e aprovação.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 5 — Como funcionam os sistemas de IA empresariais

Construir um modelo mental compartilhado de um sistema de IA, suas dependências e os limites que um engenheiro de segurança deve proteger.

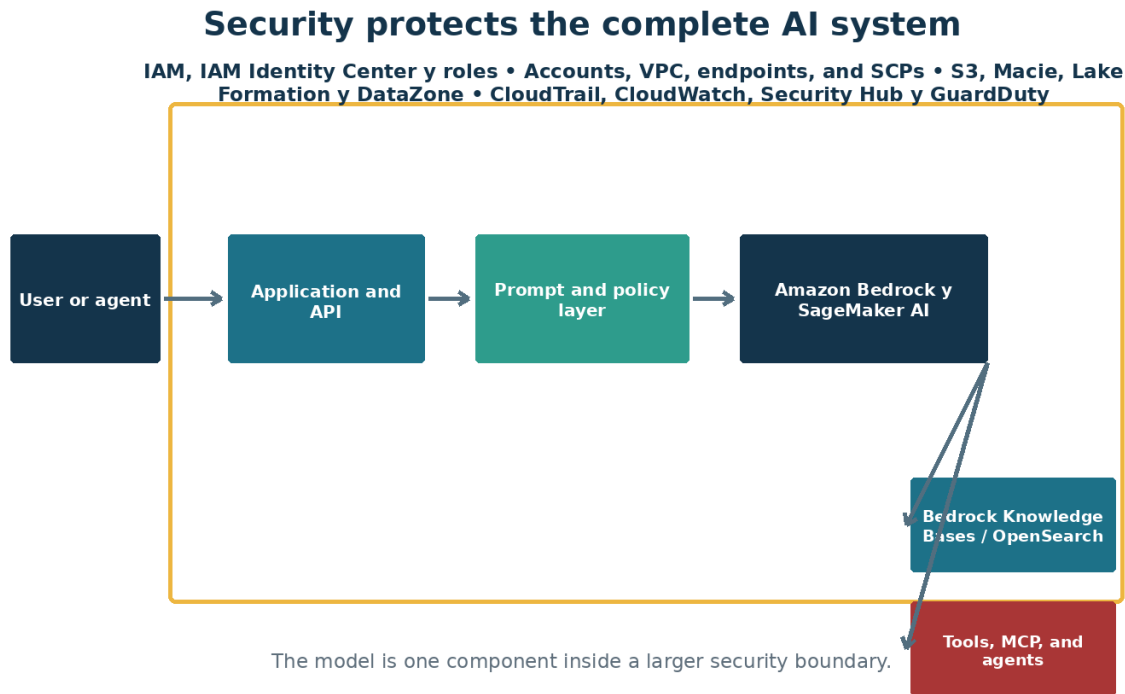


Figura 2. O modelo representa apenas uma parte da superfície de ataque da IA empresarial.

O sistema é maior que o modelo.

Um modelo de linguagem é apenas um componente. Um serviço de produção também contém um aplicativo, identidades, prompts, fontes de dados, serviços de recuperação, ferramentas, caminhos de rede, logs, administradores e usuários. Falhas de segurança geralmente ocorrem onde esses componentes se conectam. Comece cada revisão desenhando o sistema completo e indicando o responsável por cada parte.

- Configuração de endpoint e implantação do modelo
- Aplicativo e interface do usuário
- Avisos do sistema, modelos e estado da conversa
- RAG armazena, indexa, conecta e armazena documentos de origem.
- Ferramentas de agente, servidores MCP, APIs e sistemas downstream.
- Provedor de identidade, segredos, controles de rede, registro e monitoramento.

Garantia de mudanças de comportamento probabilístico

O código tradicional segue uma lógica definida. A IA generativa pode produzir respostas diferentes para a mesma solicitação, interpretar instruções incorretamente ou combinar conteúdo confiável e não confiável. Portanto, os testes exigem conjuntos de dados representativos, execuções repetidas, limites mensuráveis e

monitoramento contínuo. Uma demonstração bem-sucedida uma única vez não comprova que o sistema seja seguro.

- Testes separados de qualidade funcional, segurança, proteção, privacidade e confiabilidade.
- Registre o nome do modelo, a versão do modelo, a versão do prompt, os parâmetros e a versão do conjunto de dados.
- Teste entradas normais, incomuns, hostis e ambíguas.
- Defina o que o sistema deve recusar, encaminhar para instâncias superiores ou entregar a um humano.

Funções e responsabilidade compartilhada

Os provedores de nuvem protegem sua plataforma, mas o cliente continua responsável pela configuração, identidade, dados, lógica do aplicativo, uso legal e decisões operacionais. Os provedores de modelos não conhecem o contexto de negócios nem o dano aceitável. Atribua responsáveis pelo caso de uso, dados, modelo, segurança, privacidade, operações e supervisão humana.

- O proprietário da empresa aprova a finalidade e a tolerância ao risco.
- O proprietário dos dados aprova as fontes e as regras de acesso.
- O responsável pela área de engenharia mantém a aplicação e a sua implementação.
- A segurança valida a arquitetura, os controles, o monitoramento e a resposta.
- A governança registra decisões, evidências, exceções e revisões.

UM ASSISTENTE PRESTATIVO SE TORNA UM INCIDENTE DE SEGURANÇA

Um assistente de políticas responde corretamente durante uma demonstração. Em produção, ele recupera um relatório de investigação confidencial porque o índice vetorial não preserva as permissões do documento. O modelo funcionou conforme o esperado; a arquitetura de autorização falhou.

Exercício: Mapeie um sistema de IA completo.

- Escolha um caso de uso de assistente interno de baixo risco.
- Desenhe usuários, aplicativos, modelos, fontes de dados, índices, agentes, ferramentas, identidades, redes e registros.
- Defina os limites de confiança e cada ponto de transferência de dados.
- Indique o proprietário e as provas documentais necessárias para cada componente.
- Liste três maneiras pelas quais o sistema poderia causar danos sem estar tecnicamente comprometido.

Verificação de controle do capítulo

- ☐ Todo o sistema — e não apenas o modelo — está documentado.
- ☐ Os limites de confiança e os fluxos de dados são visíveis.

- ☐ Os proprietários e os pontos de aprovação são mencionados.
- ☐ Segurança, privacidade, proteção e confiabilidade são testadas separadamente.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 6 — Fundamentos da AWS para Segurança de IA

Crie uma base AWS governada para que os experimentos de IA não se tornem sistemas de produção não gerenciados.

Organize o inquilino e as assinaturas.

Use o AWS Organizations, unidades organizacionais, contas, padrões de nomenclatura, tags, políticas de controle de serviço e o AWS Config para tornar a propriedade e a finalidade visíveis. Separe a produção do desenvolvimento e dos testes. Uma única conta compartilhada dificulta a alocação de custos, a revisão de acesso, o isolamento e a investigação de incidentes.

- Utilize assinaturas dedicadas ou limites de recursos rígidos para a produção.
- Proprietário da etiqueta, ambiente, classificação de dados, centro de custos e data de expiração.
- Aplique políticas de controle de serviço, regras do AWS Config e diretrizes do Control Tower para regiões permitidas, redes privadas, criptografia, registro de logs e serviços aprovados.
- Utilize bloqueios de recursos somente onde eles não impeçam a resposta a emergências.

Identidade antes dos recursos

Defina o acesso antes de implantar os serviços. Use grupos do IAM Identity Center, conjuntos de permissões, funções do IAM, credenciais temporárias do AWS STS e revisões de acesso. Evite políticas de AdministratorAccess amplas e permissões curinga. Prefira federação de identidades e tokens temporários a credenciais armazenadas.

- Separar a administração humana do acesso ao aplicativo.
- Utilize o acesso privilegiado sob demanda.
- Atribua funções no âmbito mais restrito possível.
- Crie contas de emergência e teste seus procedimentos.
- Logins, alterações de função, consentimento e operações privilegiadas

Linha de base de rede e plataforma

Para cargas de trabalho sensíveis, utilize endpoints privados, saída controlada, segmentação de rede, planejamento de DNS, gateways de API e registro centralizado de logs. O acesso público deve ser uma decisão explícita, e não a opção padrão adotada após uma prova de conceito.

- Coloque o Amazon API Gateway na frente das APIs consumidas externamente.
- Restrinja os serviços de armazenamento, pesquisa, modelagem e segredos com controles de rede.
- Enviar registros de diagnóstico para um espaço de trabalho protegido.
- Use as descobertas do AWS Security Hub CSPM, os resultados do AWS Config e as detecções do GuardDuty como entrada — não como o programa de segurança completo.
- Defina orçamentos, quotas e alertas antes de realizar testes em larga escala.

A PROVA DE CONCEITO ESQUECIDA

Uma equipe implementa um endpoint de modelo público com uma chave de longa duração e sem alerta de orçamento. A demonstração termina, mas o recurso permanece disponível. Meses depois, a chave é encontrada em um repositório e usada para inferência não autorizada.

Exercício: Projete uma zona de aterrissagem segura na AWS.

- Crie um design lógico de assinatura e grupo de recursos para desenvolvimento, teste e produção.
- Defina as tags necessárias, os resultados da política de controle de serviço, as regras do AWS Config e as diretrizes do Control Tower.
- Funções de administrador de mapas, desenvolvedor, operador, auditor e gerenciamento de carga de trabalho.
- Defina os caminhos de rede permitidos e os destinos de registro.
- Escreva uma regra de limpeza e expiração para experimentos.

Verificação de controle do capítulo

- ☐ Os ambientes e as funções são separados.
- ☐ O acesso utiliza grupos, identidades gerenciadas e o princípio do menor privilégio.
- ☐ A exposição da rede é intencional e documentada.
- ☐ O registro de dados, os orçamentos, as quotas e as regras de limpeza são definidos antes da implantação.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 7 — Confiança Zero e Defesa em Profundidade para IA

Aplique princípios de segurança já conhecidos a fluxos de dados, ferramentas, memória e ações autônomas específicas de IA.

Defense in depth for enterprise AI

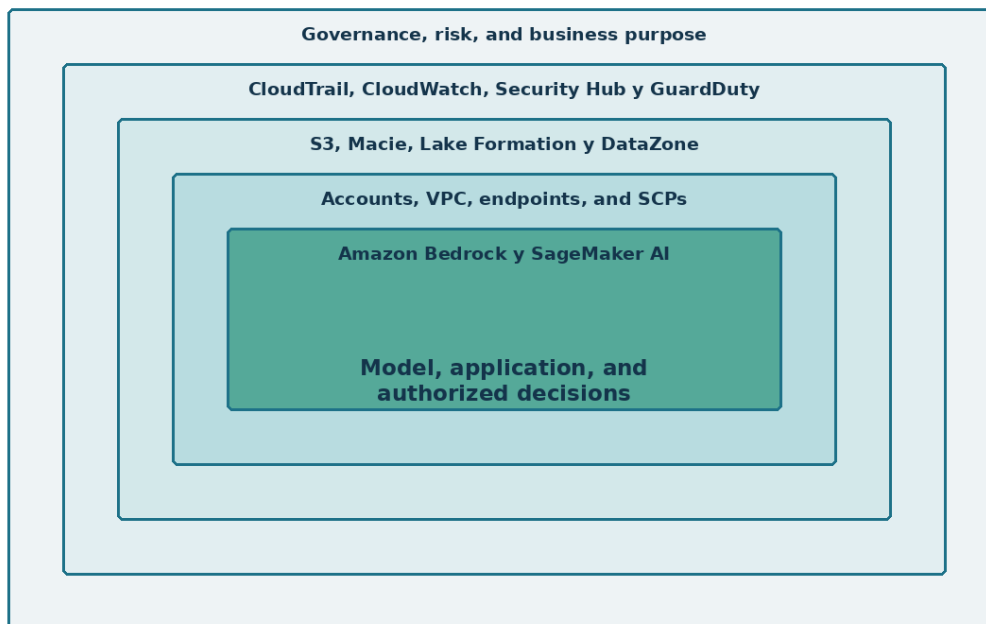


Figura 3. A segurança da IA depende de várias camadas independentes.

Verifique explicitamente

Cada usuário, carga de trabalho, agente, ferramenta e solicitação de dados precisa de uma identidade verificada e uma decisão de autorização. Não considere uma solicitação como confiável apenas porque ela veio por meio de uma interface de chat ou porque foi gerada por um agente. O modelo não é um mecanismo de autorização.

- Autenticar em cada limite de serviço
- Autorize a ação e os dados solicitados — não apenas o acesso ao aplicativo.
- Verifique novamente a autorização quando um agente chamar uma ferramenta.
- Preserve o contexto do usuário sem conceder ao agente todos os privilégios do usuário.
- Registre o ator, o sujeito, o recurso, a ação, a decisão e o resultado.

Use o princípio do menor privilégio e assuma o compromisso.

Limitar o que uma injeção de prompt bem-sucedida, um token roubado, um conector comprometido ou um agente defeituoso podem fazer. Permissões restritas, limites de transação, sandbox, aprovação humana e separação de ambientes reduzem o raio de impacto.

- Dê aos agentes ferramentas específicas para cada tarefa, em vez de interfaces genéricas.
- Utilize o acesso somente leitura, a menos que seja necessária alguma modificação.
- Defina limites de gastos, consultas, arquivos e transações.
- Exigir aprovação para exclusão, pagamento, identidade, questões legais, segurança e alterações de produção.
- Crie um método rápido para desativar um agente, identidade, conector ou implantação de modelo.

Sobreponha os controles

Nenhum filtro isolado consegue proteger um sistema de IA. É necessário combinar controles de identidade, rede, dados, aplicação, modelo, monitoramento e governança. Filtros de conteúdo reduzem certos resultados prejudiciais, mas não substituem a autorização, a programação segura ou a supervisão humana.

- Prevenção por meio da arquitetura e do princípio do menor privilégio.
- Detectar com base em registros, sinais comportamentais, avaliações e alertas.
- Responda com estratégias e procedimentos de revogação já testados.
- Recupere-se com serviços de reversão, backups e contingência seguros e testados.

UM MODELO SEGURO COM UMA FERRAMENTA INSEGURA

Um agente possui um prompt de sistema bem testado, mas também uma ferramenta capaz de excluir recursos na nuvem. Um documento malicioso instrui o agente a executar essa ferramenta. A defesa correta não reside em uma frase mais forte no prompt, mas sim em permissões restritas, separação de entrada, aprovação e controles de transação.

Exercício: Construa um mapa de controle de defesa em profundidade

- Selecione um agente que possa pesquisar documentos e abrir um chamado de serviço.
- Liste os controles preventivos, de detecção, de resposta e de recuperação.
- Indique quais controles permanecem eficazes caso as defesas imediatas falhem.
- Identifique o raio máximo plausível da explosão.
- Adicione um controle que reduza o raio da explosão em pelo menos metade.

Verificação de controle do capítulo

- ☐ O modelo nunca é usado como o responsável pela tomada de decisão de autorização.
- ☐ As permissões de agente e ferramenta são específicas para cada tarefa.
- ☐ Ações com consequências exigem controles mais rigorosos.

☐ Prevenção, detecção, resposta e recuperação estão todas representadas.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 8 — Modelagem de Ameaças em IA e Sistemas Agentes

Identifique as fragilidades do projeto antes da implementação, modelando ativos, fluxos de dados, limites de confiança, uso indevido e falhas.

Comece pelos ativos e pelos danos.

Proteja mais do que a confidencialidade. Os ativos importantes de IA incluem instruções, acesso ao modelo, incorporações, integridade da fonte, confiança do usuário, qualidade da decisão, permissões da ferramenta, orçamento, segurança e trilha de auditoria. Descreva os danos que poderiam ocorrer se cada ativo for divulgado, alterado, destruído ou usado indevidamente.

- Dados sensíveis e regulamentados
- Avisos do sistema, políticas e conhecimento proprietário
- Integridade do modelo, conjunto de dados, incorporação e índice
- Credenciais do agente e autoridade delegada
- Correção, disponibilidade, custo, reputação e segurança humana.

Mapeie os fluxos de dados e controle reais.

Mostre onde os prompts são montados, onde o conteúdo recuperado entra em contexto, onde a memória é armazenada e onde as ferramentas são invocadas. Marque o conteúdo externo como não confiável, mesmo que pareça texto comum. Documente os caminhos administrativos e de manutenção com o mesmo cuidado que os caminhos do usuário.

- Fluxo do usuário para o aplicativo e do aplicativo para o modelo
- Ingestão, fragmentação, incorporação, indexação, recuperação e exclusão.
- Chamadas de agente para ferramenta, MCP, API e agente para agente
- Telemetria, avaliação, suporte e caminhos de resposta a incidentes.
- Dependências de terceiros em modelos, conectores, pacotes e SaaS.

Uso indevido e falha do modelo em conjunto

Uma revisão segura inclui ataques maliciosos, erros comuns, limitações do modelo, combinações inesperadas e falhas operacionais. Utilize o STRIDE para componentes convencionais, o OWASP para riscos de aplicação, o MITRE ATLAS para técnicas de IA adversárias e cenários de danos estruturados para pessoas e processos de negócios.

- Injeção imediata, envenenamento, extração, evasão e exfiltração.
- Excesso de agência e comportamento de delegado confuso
- Alucinações, preconceito, dependência excessiva da automação e conselhos inseguros.
- Interrupção de serviço, esgotamento de cotas, custos exorbitantes, conhecimento obsoleto e desativação de modelos.
- Abuso por parte de funcionários internos, administradores, fornecedores e contas comprometidas.

LIMITE DE CONFIANÇA OCULTO DENTRO DE UM PDF

Um fluxo de trabalho de triagem de currículos recupera texto de PDFs enviados. O diagrama de arquitetura mostra o serviço de upload, mas não o ponto em que o texto do documento se torna instruções do modelo. Um atacante insere instruções ocultas em um PDF e altera o comportamento do agente.

Prática: Modele ameaças em um assistente de documentos.

- Identificar ativos, atores, pontos de entrada, dependências e limites de confiança.
- Descreva dez cenários de uso indevido ou falha.
- Avalie a probabilidade e o impacto utilizando a metodologia da organização.
- Atribua controles preventivos e de detecção aos riscos mais elevados.
- Registre o risco residual, o proprietário, a data de vencimento e a autoridade de aceitação.

Verificação de controle do capítulo

- ☐ Ativos não tradicionais, como confiança, correção e custo, estão incluídos.
- ☐ O conteúdo recuperado e as chamadas de ferramentas aparecem como limites de confiança.
- ☐ Falhas maliciosas e acidentais são ambas modeladas.
- ☐ O risco residual possui uma autoridade de aceitação designada.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

PARTE II — CONSTRUINDO IA NA AWS

Crie serviços de IA úteis com limites seguros desde o início.

COMPREENDER • APLICAR • TESTAR • COMPROVAR

Capítulo 9 — Amazon Bedrock e SageMaker AI: Projetos, Modelos e Controles

Utilize o Amazon Bedrock e o SageMaker AI como um ambiente de engenharia controlado, em vez de um ambiente isolado para testes de modelos.

Compreenda o papel da plataforma

O Amazon Bedrock fornece acesso controlado a modelos fundamentais, diretrizes, bases de conhecimento, agentes, avaliação e observabilidade; o SageMaker AI oferece suporte a uma construção de modelos mais abrangente, personalização, implantação e MLOps. Um projeto deve ter um propósito de negócio definido, classificação de dados, responsável, ambiente, orçamento e plano de lançamento. O sucesso no ambiente de testes é o início da engenharia — não a aprovação para produção.

- Crie projetos e conexões separados para cada ambiente.
- Limitar quem pode implantar modelos ou alterar conexões
- Use identidades gerenciadas e conexões aprovadas.
- Registre a região, o provedor, o tipo de implantação, a cota e a configuração do filtro de conteúdo.
- Exportar comprovantes de avaliações e aprovações.

Selecione modelos deliberadamente

Escolha um modelo com base no caso de uso e nas evidências. Um modelo maior ou mais recente não é automaticamente mais seguro ou mais apropriado. Compare qualidade, latência, custo, limitações de contexto, suporte de ferramentas, tratamento de dados, região, termos contratuais, comportamento de segurança e portabilidade.

- Crie um conjunto de dados de avaliação representativo antes da seleção.
- Teste pelo menos uma alternativa razoável.
- Limitações do modelo de documento e do provedor
- Confirme os termos de processamento e retenção de dados.
- Planeje mudanças de versão, descontinuação e contingência.

Separe a experimentação do lançamento.

Utilize um processo de liberação que exija revisão de arquitetura, modelo de ameaças, aprovação de dados, revisão de identidade, resultados de avaliação, descobertas de equipe vermelha, monitoramento, manual de incidentes e aceitação da área de negócios. As alterações em produção devem ser rastreáveis e reversíveis.

- Solicitações de versão, código, implantações de modelos, conjuntos de dados e configurações de avaliação.
- Exigir revisão por pares para instruções do sistema e definições de ferramentas.

- Proteja as conexões e os segredos de produção.
- Repetir o teste após alterações no modelo, no prompt, na recuperação de dados, na ferramenta ou na política.

O modelo muda, mas a aprovação não.

Uma equipe substituiu uma implantação de modelo para melhorar a qualidade. A nova versão se comporta de maneira diferente em relação a rejeições e chamadas de ferramentas, mas nenhum teste de regressão é executado porque o código do aplicativo não foi alterado.

Exercício: Crie um registro de lançamento do Bedrock ou do SageMaker AI.

- Defina um projeto de exemplo, incluindo seu proprietário, finalidade, classificação de dados e ambiente.
- Compare dois modelos candidatos usando cinco critérios de qualidade e cinco critérios de risco.
- Crie uma lista de verificação para a liberação e uma lista de evidências necessárias.
- Defina os gatilhos de reversão e o modelo de fallback aprovado.
- Registre os componentes exatos que precisam ser testados novamente após a alteração.

Verificação de controle do capítulo

- ☐ Todo projeto tem um responsável, um objetivo, uma classificação e um orçamento.
- ☐ A seleção do modelo é apoiada por evidências de avaliação.
- ☐ As tarefas de experimentação e produção são separadas.
- ☐ As alterações são versionadas, testadas novamente, aprovadas e reversíveis.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 10 — OpenAI, Claude e as escolhas dos fornecedores de modelos

Entenda as opções de implantação e evite confundir um aplicativo de consumidor com um serviço de API empresarial.

Diferencie os serviços

O ChatGPT é um aplicativo e espaço de trabalho da OpenAI. A API da OpenAI é uma plataforma para desenvolvedores. Os modelos da OpenAI podem ser consumidos diretamente pela API da OpenAI, enquanto as rotas de modelos da AWS geralmente usam o Amazon Bedrock ou o SageMaker AI sob os controles da AWS. O Claude pode ser obtido diretamente da Anthropic ou por meio de plataformas de nuvem compatíveis, incluindo o Amazon Bedrock, quando disponível. Os modelos de segurança, faturamento, identidade, retenção, região e recursos podem variar de acordo com a rota.

- Documente a parte contratante e o processador de dados.
- Confirme se os dados do cliente são retidos ou usados para melhoria do serviço.
- Verifique a disponibilidade da região e do recurso.
- Utilize espaços de trabalho corporativos e APIs para dados empresariais.
- Não presuma que uma assinatura pessoal tenha controles empresariais.

Criar uma avaliação do provedor

Avalie os fornecedores e as rotas de implantação usando as mesmas perguntas de controle. Analise as declarações de segurança, o fluxo de dados, os subprocessadores, a notificação de incidentes, o ciclo de vida do modelo, o monitoramento de abusos, os controles administrativos, o registro de logs, a disponibilidade, a portabilidade e o suporte à saída.

- O registro permitiu a classificação dos dados para cada rota.
- Analise as opções de autenticação e gerenciamento de chaves.
- Confirme se os registros estão disponíveis para o cliente.
- Compreenda os processos de filtragem de conteúdo e de recurso.
- Testar o efeito das alterações do provedor no comportamento do aplicativo.

Design para portabilidade controlada

Evite vincular regras críticas de autorização ou de negócio ao comportamento de um único modelo. Utilize uma camada de controle de aplicação, conjuntos de dados de avaliação normalizados, adaptadores específicos do provedor e planos de contingência documentados. A portabilidade tem um custo, mas limites controlados reduzem o risco de migrações emergenciais.

- Manter a aplicação das políticas fora do modelo
- Manter casos de teste independentes do fornecedor

- Separe os prompts do código-fonte sempre que possível.
- Acompanhe os recursos e limitações específicos do provedor.
- Teste alternativas para qualidade, segurança, latência e custo.

Os dados comerciais são inseridos em uma conta pessoal.

Um funcionário utiliza uma assinatura pessoal de IA para resumir um contrato de cliente porque a interface é idêntica ao ambiente de trabalho corporativo aprovado. O controle ausente não é a inteligência do usuário; o que falta são políticas claras, descoberta técnica, treinamento e uma alternativa aprovada e fácil de usar.

Exercício: Comparar rotas de implantação

- Compare a API direta da OpenAI, uma rota com modelo Amazon Bedrock, a API direta do Claude e o Claude por meio do Amazon Bedrock.
- Registre as diferenças de identidade, rede, logs, retenção, região, faturamento e contrato.
- Defina as classificações de dados permitidas para cada uma.
- Escolha uma das opções para um assistente interno regulamentado e explique a decisão.

Verificação de controle do capítulo

- ☐ Os aplicativos de bate-papo e as APIs para desenvolvedores são claramente distintos.
- ☐ Os riscos relacionados ao provedor e à rota de implantação estão documentados.
- ☐ As classificações de dados permitidas são explícitas.
- ☐ O recurso de fallback não ignora os controles de segurança ou governança.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 11 — Estímulo, Contexto, Memória e Segurança do Conteúdo

Considere os avisos e o contexto como componentes controlados da aplicação, reconhecendo, porém, que eles não representam limites de segurança.

Instruções do sistema de engenharia

Escreva instruções claras que definam a função, as tarefas permitidas, as ações proibidas, a escalação, o uso da fonte, a incerteza, as citações e o comportamento da ferramenta. Armazene e versione avisos como se fossem código. Um aviso do sistema pode orientar o comportamento, mas os usuários ou o conteúdo recuperado ainda podem manipular o modelo.

- Mantenha as instruções concisas e testáveis.
- Separe o conteúdo não confiável das instruções.
- Indique quando recusar ou pedir aprovação.
- Exigir a divulgação da incerteza e da fonte quando apropriado.
- Nunca insira segredos em prompts do sistema.

Controle de memória e contexto

O histórico de conversas, a memória de longo prazo, as passagens recuperadas, os arquivos enviados e os resultados das ferramentas se tornam contexto. Defina o que pode ser armazenado, por quanto tempo, quem pode acessá-lo e como ele é excluído. Não permita que a memória de um usuário influencie a sessão de outro.

- Classificar o conteúdo da memória e definir a retenção.
- Impeça a recuperação de informações entre usuários e entre locatários.
- Validar e rotular as saídas da ferramenta
- Limitar o contexto ao que for necessário
- Forneça um método para corrigir ou excluir informações armazenadas.

Use a segurança de conteúdo como uma camada.

Os serviços de segurança de conteúdo podem detectar categorias de textos ou imagens prejudiciais e oferecem suporte a filtros configuráveis. Eles não comprovam a veracidade dos fatos, não impedem o vazamento de dados, não aplicam autorização nem bloqueiam todos os jailbreaks. Ajuste os limites de acordo com o seu caso de uso real e examine tanto os falsos negativos quanto os falsos positivos.

- Teste os filtros de entrada e saída separadamente.
- Criar mensagens de contingência seguras
- Decisões de filtragem de logs sem reter desnecessariamente conteúdo sensível.
- Estabelecer processos de revisão e apelação
- Realizar novo teste após alterações nas políticas, modelos, linguagem ou público-alvo.

O SEGREDO NO SISTEMA PROMPT

Um desenvolvedor coloca uma credencial de banco de dados em um prompt do sistema e instrui o modelo a nunca revelá-la. Um atacante usa técnicas repetidas de extração e obtém a credencial. Instruções não podem substituir um gerenciador de segredos.

Exercício: Crie e teste uma instrução de sistema.

- Escreva uma instrução de sistema para um assistente de políticas.
- Defina as tarefas permitidas, as condições de recusa, as citações, a incerteza e a escalação.
- Crie testes normais, ambíguos, hostis e de injeção indireta.
- Registre os critérios de aprovação e o comportamento inesperado.
- Mova todas as decisões de segurança e autorização para fora do prompt.

Verificação de controle do capítulo

- ☐ Os prompts são versionados e revisados por pares.
- ☐ Não há segredos nem decisões finais de autorização armazenadas em prompts.
- ☐ A memória possui regras de isolamento, retenção, correção e eliminação.
- ☐ Os filtros de conteúdo são testados e tratados como uma única camada.

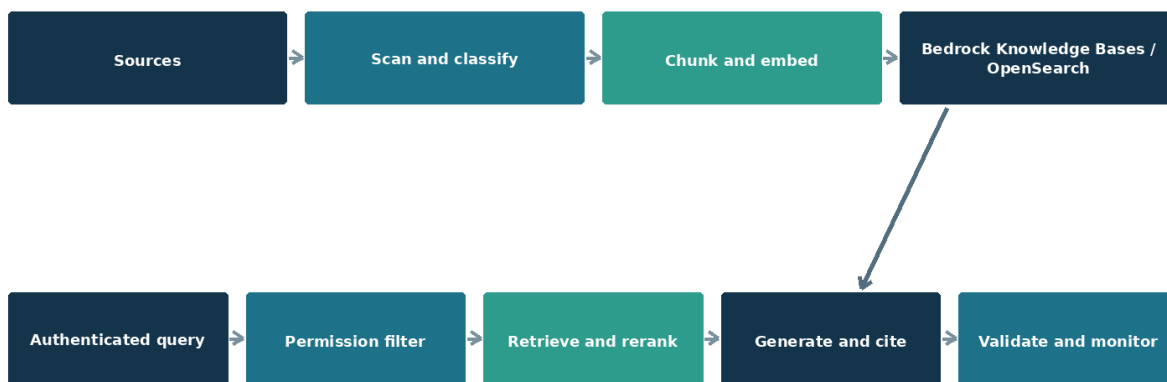
EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 12 — Geração Aumentada de Recuperação Segura

Crie um RAG que melhore as respostas sem criar um novo caminho para contornar os controles de autorização e retenção de dados.

Secure RAG: authorization must survive retrieval



Lineage and deletion apply to files, chunks, embeddings, indexes, prompts, and logs.

Figura 5. O Secure RAG preserva a autorização, a linhagem e o monitoramento em todo o pipeline.

Entenda o pipeline RAG

O RAG recupera material relevante e o adiciona ao contexto do modelo. Ele não ensina o modelo permanentemente nem garante uma resposta correta. O pipeline inclui ingestão, varredura, análise sintática, fragmentação, metadados, incorporação, indexação, consulta, filtragem, reclassificação, geração, citação e exclusão. Cada etapa precisa de um responsável e controles.

- Manter a linhagem desde o documento de origem até cada fragmento e elemento incorporado.
- Proprietário da fonte de dados, classificação, permissões, região, retenção e expiração.
- Analisar e validar arquivos antes da análise sintática.
- Mantenha as alterações de origem e índice rastreáveis.
- Exclusão do design para que o conteúdo derivado seja removido.

Preservar a autorização durante a recuperação.

O acesso do aplicativo não autoriza todos os documentos indexados. Imponha o acesso em nível de documento ou de bloco usando as permissões de usuário autenticado, grupos, localatário, finalidade e origem. Aplique a filtragem antes que o conteúdo chegue ao modelo. Nunca peça ao modelo para decidir se uma passagem recuperada é permitida.

- Use o recurso de restrição de segurança e negue por padrão.

- Teste o isolamento entre usuários e entre inquilinos
- Impedir a passagem do filtro de metadados
- Utilize identidades gerenciadas entre componentes de recuperação.
- Registre a identidade da consulta, os filtros, os identificadores de origem e o resultado da autorização.

Defenda a base de conhecimento.

Trate todos os documentos como entradas não confiáveis. Um documento pode conter instruções ocultas ou visíveis destinadas ao modelo. Separe os dados recuperados das instruções do sistema, identifique as fontes autorizadas, restrinja a ingestão, detecte alterações inesperadas e teste o conteúdo comprometido.

- Aprovar conectores e fontes de ingestão
- Utilize checksums, procedência e revisão de alterações para conteúdo crítico.
- Detectar injeção indireta por estímulo e instruções suspeitas.
- Limitar a quantidade recuperada e o contexto.
- Exija citações que possam ser abertas e verificadas.

Avaliar a recuperação e as respostas.

Meça a qualidade da recuperação separadamente da qualidade da geração. Uma resposta fluente pode estar fundamentada em uma fonte incorreta. Use perguntas representativas e avalie a precisão, a abrangência, a relevância do contexto, a fundamentação, a completude, a correção da citação, a recusa, a latência, o custo e o comportamento de segurança.

- Incluir perguntas sem resposta no corpus
- Teste documentos conflitantes, desatualizados, duplicados e maliciosos.
- Defina pontuações mínimas e regras de revisão manual.
- Repetir avaliações após alterações no corpus, chunking, embedding, modelo, prompt ou classificação.

DOCUMENTO EXCLUÍDO, INCORPORAÇÃO SOBREVIVENTE

Um documento legal é removido do armazenamento devido a uma solicitação de retenção, mas partes dele permanecem no índice de pesquisa. O assistente continua a exibir trechos porque a exclusão foi implementada apenas para o arquivo original.

Prática: Modele ameaças e teste um assistente RAG.

- Crie um pequeno conjunto de documentos com documentos públicos, internos e restritos.
- Defina metadados e filtros de permissão.
- Adicione um documento inofensivo contendo uma string de teste de injeção indireta.
- Teste de recuperação autorizada, recuperação negada, respostas desconhecidas, citações e exclusão.
- Documente todos os artefatos necessários para comprovar o controle de acesso e a remoção.

Verificação de controle do capítulo

- ☐ As permissões de origem permanecem válidas mesmo após a ingestão e recuperação.
- ☐ Os documentos são tratados como entrada não confiável.
- ☐ A linhagem e a exclusão abrangem fragmentos e incorporações.
- ☐ A recuperação e a geração são avaliadas separadamente.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 13 — Agentes, Ferramentas, MCP e Comunicação entre Agentes

Restringir os sistemas autônomos e semiautônomos para que as instruções em linguagem natural não se tornem, silenciosamente, autoridade ilimitada.

Compreenda o ciclo do agente.

Um agente observa, raciocina, escolhe uma ferramenta, age, recebe um resultado e continua. Cada ciclo pode amplificar um erro ou ataque. Defina uma meta delimitada, um número máximo de etapas, ferramentas aprovadas, limites de tempo e gastos, condições de parada e ações que exigem aprovação humana.

- Utilize agentes especialistas com funções específicas em vez de um único agente onipotente.
- Defina limites de iteração, tempo, token e transação.
- Validar argumentos e resultados da ferramenta
- Impedir delegação recursiva sem limites
- Registre um rastreamento que conecte instrução, decisão, chamada da ferramenta, identidade e resultado.

Ferramentas seguras e MCP

O MCP padroniza a forma como os modelos descobrem e utilizam ferramentas e contexto. Trate cada servidor, descrição de ferramenta, esquema, recurso retornado e fluxo de autenticação como uma decisão de cadeia de suprimentos e limite de confiança. Uma descrição de ferramenta atraente não comprova que a ferramenta seja segura.

- Aprovar e inventariar servidores MCP
- Autenticar clientes e servidores
- Fixar versões e verificar fontes de distribuição
- Analise as descrições das ferramentas em busca de instruções ocultas ou enganosas.
- Ferramentas e destinos da lista de permissões
- Execução de código em sandbox e acesso a arquivos
- Exigir confirmação para ações consequentes

Delegação de controle e confiança entre agentes

Um agente que recebe uma solicitação de outro agente não deve presumir que o remetente esteja autorizado a realizar a ação solicitada. Autentique ambas as partes, preserve o usuário e a finalidade de origem, restrinja os escopos delegados e registre a cadeia de autoridade.

- Utilize relações de confiança explícitas
- Evite passar tokens amplos reutilizáveis.
- Defina o nível de delegação e o prazo de validade.
- Separar a troca de dados das instruções executáveis

- Detectar trabalho circular, desvio de tarefas e acúmulo de privilégios.

A FERRAMENTA ÚTIL, MAS MALIGNA

Um desenvolvedor instala um servidor MCP não revisado que oferece conversão de documentos prática. Os metadados da ferramenta instruem o modelo a enviar o conteúdo do documento para um endpoint externo. O agente segue a descrição porque o servidor foi considerado confiável.

Exercício: Analise o design de um agente.

- Defina um objetivo de negócio e as ferramentas mínimas necessárias.
- Atribua uma identidade e um conjunto de permissões distintos a cada agente e ferramenta.
- Liste as ações que requerem confirmação.
- Defina limites de etapas, tempo, custo, destino e transação.
- Redija procedimentos de desligamento e preservação de evidências.

Verificação de controle do capítulo

- ☐ Os agentes têm objetivos, tempo, etapas, custos e permissões limitados.
- ☐ Os servidores e ferramentas MCP são inventariados e aprovados.
- ☐ A delegação preserva a identidade, o propósito, o escopo e a auditabilidade.
- ☐ Ações com consequências exigem controles determinísticos ou aprovação humana.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 14 — Amazon Q e IA para Produtividade Empresarial

Garantir o uso organizacional seguro do Amazon Q e de outros assistentes de produtividade, onde as permissões existentes e o compartilhamento excessivo representam riscos para a IA.

O acesso existente se transforma em alcance de IA

Um assistente de produtividade pode descobrir e resumir rapidamente informações às quais o usuário já tem acesso. Ele pode expor compartilhamentos excessivos de longa data que eram difíceis de encontrar manualmente. Antes da implementação em larga escala, revise as permissões do SharePoint, Teams, OneDrive, caixas de correio e grupos, e defina a propriedade dos repositórios confidenciais.

- Descubra informações compartilhadas em excesso e sem rótulo.
- Remover links genéricos e associações desatualizadas a grupos.
- Aplique etiquetas de sensibilidade e DLP
- Priorize os dados executivos, jurídicos, de RH, financeiros, de segurança e de clientes.
- Teste com funções de usuário representativas

Agentes governamentais e extensões

Os aplicativos, plugins, conectores, ações e fontes de dados indexados do Amazon Q Business expandem a capacidade e aumentam o risco. Estabeleça um processo de entrada, ambientes aprovados, política de conectores, requisitos de proprietário e patrocinador, classificação de dados, testes, aprovação de publicação, monitoramento e desativação.

- Funções separadas de criador e editor de produção
- Restringir conectores e caminhos de perda de dados
- Políticas de uso do meio ambiente e dos inquilinos
- Agentes de inventário publicados
- Analise os proprietários, as permissões, a utilização e a inatividade.

Gerenciar a adoção com segurança

Os usuários precisam de exemplos claros de informações permitidas e proibidas, como verificar as respostas, quando a revisão humana é necessária e como relatar um problema. Bloquear todas as ferramentas sem uma alternativa aprovada fomenta a IA paralela.

- Oferecer treinamento específico para a função.
- Publique um diretório de ferramentas aprovadas
- Explique que o conteúdo gerado pode estar incorreto.
- Exigir verificação da fonte para trabalhos consequentes
- Meça o comportamento de risco e aprimore os controles sem tratar a educação como vigilância.

O COPILOT ENCONTRA O QUE A BUSCA NÃO CONSEGUIU

Um gerente solicita informações sobre planejamento salarial. O Copilot localiza uma planilha compartilhada por meio de um link antigo usado em toda a organização. O Copilot não contornou as permissões; ele facilitou a exploração de uma falha existente no controle de acesso.

Prática: Prepare uma implementação de IA para aumentar a produtividade

- Identifique cinco repositórios de alto risco.
- Defina permissões, rotulagem, DLP e verificações de propriedade.
- Crie regras de publicação de agentes e de aprovação de conectores.
- Escreva dez exemplos de uso seguro e cinco exemplos de uso proibido.
- Defina as métricas de adoção, risco e incidentes.

Verificação de controle do capítulo

- ☐ O excesso de compartilhamento de informações é abordado antes da implementação em larga escala.
- ☐ Agentes, conectores e extensões possuem governança de ciclo de vida.
- ☐ Os usuários podem distinguir entre serviços aprovados e serviços pessoais.
- ☐ Os resultados consequentes exigem verificação e responsabilidade humana.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

PARTE III — PROTEGENDO SISTEMAS DE IA

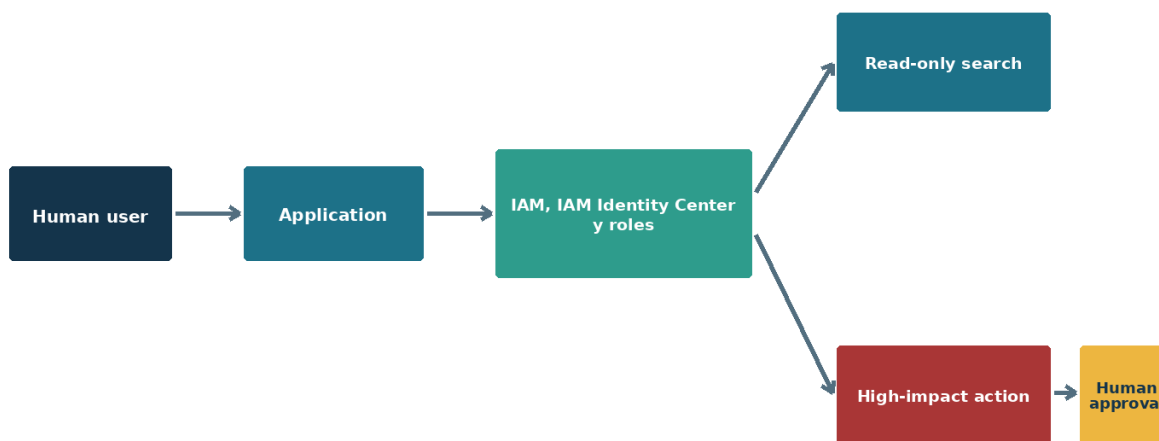
Aplique medidas de segurança relacionadas à identidade, dados, aplicativos, modelos e infraestrutura.

COMPREENDER • APLICAR • TESTAR • COMPROVAR

Capítulo 15 — Segurança de Identidade e Identidades Não Humanas

Atribua a cada usuário, carga de trabalho, aplicativo e agente uma identidade governada com autoridade limitada e um ciclo de vida completo.

Identity and approval constrain agent authority



Record the user, agent, delegated scope, tool, authorization decision, and result.

Figura 6. A identidade do agente e a aprovação humana limitam a autoridade delegada.

Escolha a identidade certa

O AWS IAM Identity Center gerencia o acesso da força de trabalho, enquanto as funções do IAM representam aplicativos, serviços, automação e agentes. As funções de carga de trabalho e o AWS STS eliminam a necessidade de armazenar muitas credenciais de longa duração. Escolha um tipo de identidade que ofereça suporte à autenticação de curta duração, propriedade clara, autorização restrita e logs úteis.

- Evite contas de usuário ou de serviço compartilhadas.
- Prefira a federação de identidades gerenciadas ou de identidades de carga de trabalho.
- Utilize princípios de serviço somente com propriedade e finalidade documentadas.
- Use identidades de agente dedicadas para agentes governados.
- Não permita que humanos realizem trabalhos rotineiros por meio de identidades não humanas.

Gerir o ciclo de vida do NHI

Identidades não humanas frequentemente superam em número as pessoas e são fáceis de esquecer. Cada identidade precisa de um registro de inventário, proprietário ou patrocinador, propósito, ambiente, credenciais, permissões, dependências, data de criação, data de revisão e gatilho de desativação.

- Descubra identidades desconhecidas e inativas

- Analise as permissões e o uso recente.
- Rotacione ou elimine segredos antigos.
- Identidades separadas para desenvolvimento, teste e produção.
- Desative antes de excluir quando as dependências forem incertas.
- Remova identidades, consentimentos, funções, segredos e relações de confiança durante o processo de desligamento.

Aplique as lições do OWASP NHI.

A lista OWASP Non-Human Identities Top 10 destaca problemas como desligamento inadequado de funcionários, vazamento de segredos, vulnerabilidade de identidades de terceiros, autenticação insegura, privilégios excessivos, configuração insegura em nuvem, segredos de longa duração, isolamento fraco do ambiente, reutilização de identidades e uso de identidades não humanas por humanos. Considere esta lista como um guia de projeto e auditoria.

- Analise repositórios, pipelines, imagens e configurações em busca de segredos.
- Use certificados ou federação em vez de chaves estáticas sempre que possível.
- Atribua os escopos de recursos e API mais restritos.
- Avaliar agentes terceirizados e automação
- Alerta sobre logins incomuns, locais, uso de tokens e alterações de permissões.

Controle delegado e acesso autônomo

Um agente assistivo pode agir em nome de um usuário autenticado, enquanto um agente autônomo pode usar as permissões do aplicativo. Registre tanto o agente quanto o sujeito representado. A delegação não deve expandir silenciosamente o acesso do usuário, e as permissões autônomas devem ser especialmente restritas.

- Diferenciar permissões delegadas de permissões de aplicação.
- Exigir consentimento e aprovação adequados ao impacto
- Preservar a identidade do usuário, agente, finalidade e ferramenta nos registros.
- Utilize a aprovação humana para ações sensíveis.
- Crie um caminho de revogação de emergência testado.

O proprietário sai, mas o agente permanece.

Um funcionário cria um agente com amplas permissões de aplicação e deixa a empresa. A conta de usuário é desativada, mas a identidade e o segredo do agente continuam funcionando porque a propriedade e o desligamento nunca foram vinculados.

Exercício: Crie um cadastro no NHI (National Health Insurance).

- Inventarie cinco exemplos de identidades gerenciadas, entidades de serviço, pipelines, chaves de API e agentes.

- Proprietário do registro, finalidade, permissões, credenciais, ambiente e último uso.
- Identificar reutilização, privilégios excessivos, segredos de longa duração e falhas no processo de desligamento de funcionários.
- Redija as etapas de remediação e revogação de emergência.
- Defina as evidências necessárias para uma revisão trimestral de acesso.

Verificação de controle do capítulo

- ☐ Cada NHI (National Health Information - Informação Nacional de Saúde) é única, possui um proprietário específico, um propósito definido e é inventariada.
- ☐ É preferível a autenticação de curta duração ou federada.
- ☐ O isolamento ambiental e o princípio do menor privilégio são aplicados.
- ☐ O processo de desvinculação remove a identidade, as credenciais, as permissões, o consentimento e as dependências.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 16 — Macie, DataZone, Governança de Dados, Privacidade e IA Paralela

Proteja as informações em usos de IA aprovados e não aprovados, preservando a classificação, a finalidade, a retenção e as evidências.

Conheça o patrimônio de dados

O Amazon Macie descobre dados confidenciais no Amazon S3, enquanto o AWS Lake Formation, o AWS Glue Data Catalog e o Amazon DataZone oferecem suporte à descoberta controlada, permissões, linhagem e compartilhamento de dados. Comece com um inventário de fontes confidenciais, proprietários, permissões, locais e usos de IA. A classificação sem propriedade ou ação se torna meramente decorativa.

- Utilize os recursos de Mapa de Dados e Catálogo para compreender as fontes e a linhagem.
- Aplique rótulos de confidencialidade que correspondam ao significado comercial.
- Identificar dados regulamentados, confidenciais e de alto impacto
- Registre as finalidades aprovadas para IA e os usos proibidos.
- Analise o compartilhamento excessivo de informações antes de permitir a ampla descoberta por IA.

Aplicar controles de segurança de dados

Proteção da Informação, Prevenção de Perda de Dados, Auditoria, Descoberta Eletrônica (eDiscovery), Retenção de Dados, Risco Interno, Conformidade de Comunicação e Gerenciamento de Políticas de Segurança de Dados (DSPM) para IA abordam diferentes aspectos do problema. Configure-os de acordo com o risco, o licenciamento, a jurisdição e as expectativas da força de trabalho.

- Detectar informações sensíveis em prompts e respostas.
- Restrinja a cópia ou o upload sempre que o risco assim o exigir.
- Monitore acessos e compartilhamentos incomuns.
- Preservar registros e bloqueios legais
- Proteja os dados da investigação e limite o acesso dos revisores.
- Testar as políticas em modo de auditoria antes da sua aplicação, quando apropriado.

Gerenciar IA paralela

A IA oculta inclui serviços de bate-papo não autorizados, contas pessoais, extensões de navegador, modelos, agentes, conectores e chaves de API. Combine descoberta, políticas, controles técnicos, educação e uma alternativa aprovada e fácil de usar. Uma proibição sem ferramentas eficazes incentiva o trabalho oculto.

- Publique um diretório de serviços aprovados.
- Explique os dados permitidos por serviço e tipo de conta.
- Detectar atividades de risco no navegador e na rede, onde permitido por lei.
- Ofereça um caminho de solicitação para novas ferramentas.

- Medidas de adoção e comportamento de risco
- Responda de forma proporcional e aprimore o sistema após as constatações.

Privacidade por design

Defina a finalidade, a base legal, o aviso, o consentimento (quando necessário), a minimização, o acesso, a retificação, a retenção, a eliminação, a transferência internacional e o tratamento dos direitos antes de processar informações pessoais. Avisos, resultados, incorporações, registros e revisões humanas podem conter dados pessoais.

- Realize uma avaliação de impacto sobre a privacidade ou a proteção de dados para usos de maior risco.
- Evite coletar dados apenas porque eles podem ser úteis posteriormente.
- Redija ou tokenize sempre que possível.
- Limitar os dados de produção no desenvolvimento e nas avaliações.
- Teste a exclusão em toda a origem, índice, memória, registros e backups.

O INQUILINO APROVADO E A ABA DO NAVEGADOR PESSOAL

Uma organização licencia um serviço de IA empresarial, mas os funcionários continuam usando contas pessoais porque o fluxo de trabalho aprovado é mais lento. Consequentemente, avisos confidenciais saem do ambiente controlado.

Exercício: Crie um plano de proteção de dados de IA

- Escolha um caso de uso de IA e liste todas as fontes de dados e tipos de dados derivados.
- Atribua classificação, proprietário, finalidade, acesso, região, retenção e método de exclusão.
- Defina os resultados de descoberta do Macie, permissões do Lake Formation, governança do DataZone, auditoria e postura de segurança de dados.
- Elabore um guia para funcionários com alternativas seguras.
- Teste um cenário de acesso, um de DLP e um de exclusão.

Verificação de controle do capítulo

- ☐ São registrados a propriedade, a classificação, a linhagem e a finalidade permitida dos dados.
- ☐ Estão incluídos prompts, saídas, incorporações, memória e registros.
- ☐ A IA paralela possui recursos de descoberta, política, treinamento e alternativas aprovadas.
- ☐ Os direitos de privacidade e a exclusão funcionam em todos os dados derivados.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 17 — Infraestrutura, Rede, Segredos e Proteção de API

Reforce a segurança das camadas comuns de nuvem e aplicativos que transportam tráfego e autoridade de IA.

Proteger caminhos de rede

Utilize endpoints privados para serviços sensíveis, quando suportado, controle o tráfego de saída, segmente ambientes e direcione o acesso externo por meio de gateways gerenciados. Documente DNS, certificados, firewalls, proxies e dependências. Redes privadas reduzem a exposição, mas não substituem a identidade ou a autorização de aplicativos.

- Desative o acesso à rede pública quando for desnecessário.
- Restringir destinos de saída para agentes e ferramentas
- Utilize proteção para aplicações web e APIs.
- Registro de fluxos aceitos e negados
- Teste em redes autorizadas e não autorizadas

Gerenciar segredos e chaves

Utilize o AWS Secrets Manager e o AWS Key Management Service (AWS KMS) para segredos, chaves e certificados, mas prefira designs que evitem segredos por meio de funções do IAM, federação de workloads e credenciais de curta duração do AWS STS. Separe as funções de administração e uso. Proteja as operações de recuperação e remoção de dados, pois a exclusão de uma chave pode destruir o acesso a dados protegidos.

- Nunca armazene chaves em prompts, código, cadernos, imagens ou tickets.
- Rotacionar credenciais e testar rotação
- Use permissões restritas para cofres e objetos.
- Ative o registro de logs e a proteção de recuperação adequada.
- Faça um levantamento dos consumidores antes de alterar ou desativar as credenciais.

APIs seguras e endpoints de ferramentas

Utilize o Amazon API Gateway ou controles equivalentes para autenticação, autorização, esquemas, cotas, limites de taxa, tamanho da requisição, métodos permitidos, versionamento e observabilidade. Valide os argumentos da ferramenta gerados pelo modelo exatamente como se fossem entradas de usuário não confiáveis.

- Use os escopos OAuth e a validação de público-alvo.
- Rejeitar campos desconhecidos e destinos inseguros.
- Aplique a idempotência para ações que podem se repetir.
- Defina quotas por usuário e por agente.
- Retornar erros seguros

- Não inclua informações confidenciais em URLs ou registros de log.

Use o Security Hub e o gerenciamento de postura.

As descobertas do AWS Security Hub CSPM, as detecções do GuardDuty, as informações de vulnerabilidades do Amazon Inspector e as proteções de cargas de trabalho fornecem visibilidade útil. Priorize por exposição e impacto nos negócios, verifique a aplicabilidade, atribua responsáveis e acompanhe a correção. Um painel de controle não comprova que o risco foi aceito ou corrigido.

- Ative os planos relevantes e as configurações de diagnóstico.
- Analise as recomendações relacionadas à IA.
- Integre alertas aos processos de incidentes.
- Validar a remediação
- Documentar exceções aceitas e data de expiração

O PONTO FINAL PRIVADO COM UM SEGREDO PÚBLICO

Um endpoint modelo utiliza rede privada, mas sua chave é armazenada em um repositório público. Os controles de rede dificultam o ataque, porém a credencial ainda pode ser usada por meio de um caminho permitido ou através de outro componente comprometido.

Prática: Analise um caminho de serviço seguro

- Desenhe conexões entre usuário, API, modelo, pesquisa e armazenamento.
- Identificar pontos de extremidade públicos e privados, bem como destinos de saída.
- Escolha a identidade e o tratamento de sigilo para cada conexão.
- Defina a validação e os limites da API.
- Liste os registros e alertas necessários para investigar uma solicitação de ponta a ponta.

Verificação de controle do capítulo

- ☐ O acesso público e externo é explicitamente justificado.
- ☐ A identidade gerenciada substitui os segredos armazenados sempre que possível.
- ☐ Os dados de entrada da API gerados pelo modelo são validados como não confiáveis.
- ☐ As conclusões sobre a postura tornam-se parte integrante do trabalho de remediação, que é verificado e de responsabilidade do indivíduo.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 18 — Riscos da OWASP para LLMs, Agentes, NHIs, APIs e Aplicações Web

Utilize as famílias OWASP em conjunto para que os riscos específicos de IA não ocultem as fragilidades das aplicações convencionais.

OWASP LLM Top 10

A lista LLM de 2025 abrange injeção imediata, divulgação de informações sensíveis, risco na cadeia de suprimentos, envenenamento de dados e modelos, tratamento inadequado de resultados, agência excessiva, vazamento imediato do sistema, vulnerabilidades de vetores e incorporação, desinformação e consumo ilimitado. Mapeie cada item para arquitetura, testes, monitoramento e resposta.

- A injeção imediata requer separação de entrada, privilégio mínimo, aprovação e monitoramento.
- A divulgação de informações sensíveis exige autorização, minimização, DLP (Prevenção contra Perda de Dados) e tratamento de saída.
- Os riscos na cadeia de suprimentos e de intoxicação exigem rastreabilidade, aprovação, integridade e detecção de mudanças.
- O processamento inadequado da saída requer codificação e validação.
- O excesso de autonomia exige ferramentas limitadas e limites determinísticos.
- O consumo ilimitado exige quotas, limites de produção, orçamentos e detecção de anomalias.

OWASP Agentic Top 10

Sistemas agentes introduzem manipulação de objetivos, uso indevido de ferramentas, abuso de identidade e privilégios, memória insegura, comunicação insegura, falhas em cascata e problemas de confiança entre humanos e agentes. Consulte as diretrizes atuais da OWASP sobre agentes ao projetar ou modificar agentes, pois essa área evolui rapidamente.

- Vincular agentes a objetivos aprovados
- Autenticar a comunicação entre agentes e entre agentes e ferramentas.
- Controlar as operações de escrita e recuperação de memória.
- Limitar a profundidade e os privilégios da delegação
- Exigem controle humano sobre os resultados consequentes.
- Detectar loops, desvios e falhas coordenadas

OWASP NHI, API e orientação da Web

As aplicações de IA continuam sendo aplicações web e de API. Use o NHI Top 10 para identidades de máquinas, o API Security Top 10 para interfaces expostas, o Web Top 10 para riscos de aplicações, o ASVS para requisitos de verificação e o SAMM para maturidade do programa.

- A violação de autorização continua sendo uma das principais preocupações.
- A injeção inclui SQL, comandos, modelos e prompts.

- Configurações de segurança incorretas afetam serviços de nuvem, aplicativos e modelos.
- Falhas de dependência e integridade afetam toda a cadeia de suprimentos de IA.
- O registro e os alertas devem conectar os eventos da aplicação e da IA.

Transforme listas em projetos de engenharia

Uma lista dos 10 principais riscos é uma ferramenta de conscientização, não um modelo de ameaças completo. Crie casos de teste, responsáveis pelos controles, evidências e critérios de aceitação para os riscos aplicáveis. Registre por que um risco não se aplica, em vez de deixá-lo em branco.

- Mapear o risco para o componente e o fluxo de dados
- Identificar controles preventivos e de detecção
- Criar testes positivos e negativos
- Defina gravidade e resposta.
- Repetir o teste após alteração do material.

A saída se torna código.

Um modelo resume um documento e retorna um texto contendo marcação de script. O aplicativo insere a saída em uma página da web sem codificá-la. Os controles de prompt funcionam, mas o tratamento inadequado da saída cria um risco convencional de cross-site scripting (XSS).

Exercício: Construa uma matriz de controle OWASP

- Selecione um caso de uso do agente RAG.
- Avalie todos os 10 principais itens do LLM e os riscos relevantes de agência, NHI, API e web.
- Mapeie cada risco aplicável para controle, responsável, teste, evidência e resposta.
- Faça pelo menos um teste negativo seguro para cada cinco riscos.
- Registre os riscos residuais e as decisões tomadas.

Verificação de controle do capítulo

- ☐ Os riscos relacionados a LLM, agentes, NHI, API e web são avaliados em conjunto.
- ☐ As listas da OWASP complementam, e não substituem, a modelagem de ameaças.
- ☐ Todo risco aplicável possui um controle, um teste, um responsável e evidências.
- ☐ A saída é validada antes de ser interpretada por outro sistema.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 19 — Cadeia de Suprimentos de IA, Desenvolvimento Seguro e LLMOps

Proteja modelos, dados, código, prompts, pacotes, contêineres, pipelines e artefatos de implantação desde a criação até a desativação.

Inventariar a cadeia de suprimentos de IA

Uma lista de materiais de IA deve identificar modelos, fornecedores, conjuntos de dados, incorporações, pacotes, imagens de contêiner, prompts, ferramentas, servidores MCP, APIs, conjuntos de avaliação, licenças e serviços de implantação. Registre a origem, versão, integridade, proprietário, aprovação, ambiente e limitações conhecidas.

- Utilize registros e repositórios aprovados.
- Verificar somas de verificação, assinaturas e procedência, quando disponíveis.
- Analise o código, as dependências, as imagens e os modelos de infraestrutura.
- Analisar licenças de modelos e conjuntos de dados
- Acompanhe os avisos dos fornecedores e os comunicados sobre o fim da vida útil dos produtos.

Aplique um ciclo de vida de desenvolvimento seguro.

Utilize os princípios do NIST SSDF e práticas específicas de IA em todas as etapas de planejamento, desenvolvimento, compilação, lançamento e resposta. Proteja o controle de versão, exija revisão por pares, separe funções, verifique segredos e mantenha a implantação em produção controlada e repetível.

- Modelo de ameaças antes da implementação
- Utilize a proteção de ramificação e revise as alterações.
- Gere infraestrutura repetível com Bicep ou Terraform.
- Liberações de rastreamento e assinatura
- Exigir controles de segurança, proteção, qualidade, privacidade e custo.
- Manter um processo de resposta a vulnerabilidades e problemas

Operar o LLMOps com base em evidências

Modelos de versão, prompts, configuração de recuperação, conjuntos de dados, código, filtros, políticas, ferramentas e definições de avaliação. Um registro de versão deve permitir reproduzir o que foi testado e entender o que mudou.

- Utilize ambientes separados e promoção aprovada.
- Manter linhas de base de avaliação
- Detectar deriva e regressão
- Reverter rapidamente
- Desative simultaneamente endpoints, identidades, índices, dados e dependências.

Controle modelos de código aberto e de terceiros

Os modelos de código aberto oferecem flexibilidade, mas aumentam a responsabilidade do cliente em relação à origem, integridade, licença, hospedagem, aplicação de patches, alinhamento de segurança e monitoramento. Os modelos gerenciados por terceiros transferem algumas operações, mas ainda exigem diligência prévia e controles de aplicação.

- Obtenha modelos de fontes confiáveis.
- Analise os cartões modelo e suas limitações.
- Teste para detectar backdoors, comportamentos inseguros e capacidades inesperadas.
- Ambientes de avaliação isolados
- Documentar os dados de uso aceito e proibido

UM PACOTE PRÁTICO MUDA O TUBO

Um desenvolvedor instala um pacote auxiliar de IA popular. Uma atualização comprometida lê variáveis de ambiente durante a compilação e envia uma credencial de implantação para fora da organização.

Exercício: Crie uma lista de materiais para IA.

- Faça um inventário dos modelos, dados, código, bibliotecas, imagens, prompts, ferramentas, APIs e serviços em nuvem de um aplicativo de exemplo.
- Fornecedor do registro, versão, licença, integridade, proprietário e ambiente.
- Identifique três dependências com alto impacto de substituição ou comprometimento.
- Defina o monitoramento e a resposta para cada um.
- Crie uma lista de verificação de evidências para a liberação.

Verificação de controle do capítulo

- ☐ O inventário abrange componentes de software convencionais e de IA.
- ☐ Os processos de construção e lançamento utilizam revisão, integridade e separação de funções.
- ☐ Cada versão de produção é reproduzível e reversível.
- ☐ A aposentadoria elimina dados, identidades e serviços conectados.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 20 — Avaliação, Red Teaming e Testes de Segurança

Avalie se um sistema de IA é útil, seguro, protegido, privado, confiável e acessível em condições realistas e adversas.

Elabore uma estratégia de avaliação.

Comece com o caso de uso e os cenários de dano. Crie dados de teste representativos, comportamento esperado, métodos de pontuação, limites e regras de revisão. Separe a qualidade do modelo da recuperação, segurança, privacidade, latência, confiabilidade e custo, para que uma média alta não oculte uma falha crítica.

- Inclui casos comuns, raros, ambíguos, multilíngues e contenciosos.
- Testar grupos protegidos e necessidades de acessibilidade
- Incluir casos com informações ausentes ou conflitantes
- Defina falhas inaceitáveis, independentemente da pontuação média.
- Mantenha os dados de teste controlados e versionados.

Equipe vermelha em segurança

O teste de intrusão com IA simula o uso indevido e o comportamento adversário. Requer autorização, definição de escopo, alvos seguros, condições de parada, tratamento de dados, comunicação e responsabilidade pela remediação. Ferramentas automatizadas aumentam a abrangência, mas não substituem testes humanos criativos ou revisão de arquitetura.

- Utilize alvos isolados ou não produtivos sempre que possível.
- Evite informações realmente sensíveis.
- Teste de injeção imediata direta e indireta
- Extração de testes, envenenamento, uso indevido de ferramentas, agência excessiva, evasão e exaustão de custos.
- Preservar prompts, respostas, rastreamentos, configurações e registros de data e hora.

Use as ferramentas de forma responsável.

PyRIT, recursos de avaliação de modelos do Amazon Bedrock, garak, promptfoo, Giskard e Inspect AI podem dar suporte a testes estruturados. Configure-os apenas em sistemas que você possui ou para os quais tem autorização para testar. Revise a documentação da ferramenta e o tráfego gerado antes da execução.

- Ferramenta e versão de registro
- Use contas de teste e limites aprovados.
- Higienize os resultados antes de compartilhar.
- Confirme as descobertas manualmente.
- Converter resultados em testes de regressão

Transforme resultados em ações concretas.

Uma descoberta útil explica o cenário, as pré-condições, as evidências, o impacto, os componentes afetados, a probabilidade, a lacuna de controle e a ação recomendada. Atribua um responsável e um prazo, teste novamente a remediação e documente o risco residual.

- Priorizar o dano e a possibilidade de exploração em detrimento da novidade.
- Separe os fatos confirmados do possível impacto.
- Proteja os resultados confidenciais dos testes.
- Rastrear padrões de falhas repetidas
- Relate claramente os bloqueios de lançamento não resolvidos

Uma média aceitável esconde uma falha crítica.

Um assistente obteve 96% em um conjunto de dados de qualidade, mas revelou informações restritas em dois testes de autorização. A média parece excelente; o sistema não deve ser liberado.

Exercício: Elabore uma avaliação de IA segura.

- Defina cinco testes de qualidade, cinco de segurança, cinco de proteção e cinco de privacidade.
- Defina limites e falhas que bloqueiam a liberação.
- Escolha uma ferramenta aprovada ou um método manual.
- Realize os testes em um ambiente controlado e preserve as evidências.
- Escreva uma das suas conclusões e converta-a em um teste de regressão.

Verificação de controle do capítulo

- ☐ A avaliação abrange qualidade, segurança, proteção, privacidade, confiabilidade e custo.
- ☐ Falhas críticas não podem ser simplesmente eliminadas pela média.
- ☐ O treinamento de equipes vermelhas (Red Teaming) é autorizado, tem escopo definido, é limitado e está documentado.
- ☐ Resultados confirmados tornam-se testes de regressão.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

PARTE IV — GOVERNANÇA E OPERAÇÕES

Utilize a IA de forma responsável, avalie os riscos e preserve as evidências.

COMPREENDER • APLICAR • TESTAR • COMPROVAR

Capítulo 21 — Registro, Detecção, Investigação e Resposta a Incidentes

Conecte o comportamento da IA à identidade, aos dados, aos aplicativos, à rede e às evidências na nuvem para que os incidentes possam ser detectados e contidos.

AI incident response preserves both control and context



Revoke identities and tools without destroying the traces needed to understand scope and cause.

Figura 7. O confinamento deve preservar o contexto necessário para a investigação e recuperação.

Projete um registro de auditoria de ponta a ponta.

Um rastreamento útil conecta a identidade humana ou da carga de trabalho, a sessão, o agente, a implantação do modelo, a versão do modelo de solicitação, as fontes de dados, os identificadores de documentos recuperados, os filtros, as chamadas de ferramentas, as decisões de autorização, os eventos de segurança de conteúdo, a resposta e o custo. Evite registrar conteúdo sensível, a menos que seja necessário e protegido.

- Utilize identificadores de correlação entre os serviços.
- Sincronizar hora
- Proteja a integridade e o acesso aos registros.
- Defina a retenção por meio de investigação e necessidade legal.
- Teste se os investigadores conseguem reconstruir uma transação.

Detectar comportamentos significativos

Alerta sobre uso incomum de identidade, alterações de permissão, acesso secreto, volume de consultas, recuperação negada, sinais de injeção de prompts, descumprimento de políticas, novos conectores, destinos inesperados, loops de agentes, falhas de ferramentas, picos de custo e alterações na configuração de produção.

- Crie linhas de base por usuário, agente, modelo e aplicação.
- Sincronize os alertas com as partes interessadas das áreas de operações e privacidade.

- Priorizar sinais combinados
- Registro do resultado da investigação
- Melhorar a detecção após incidentes e exercícios de equipe vermelha.

Prepare manuais de incidentes de IA.

Os manuais devem abranger divulgação de informações sensíveis, comprometimento de informações de saúde nacionais (NHI), injeção imediata, RAG contaminado, MCP ou conector malicioso, saída prejudicial, ação insegura, comprometimento do provedor, interrupção e custo descontrolado. Defina contenção que não destrua evidências.

- Desativar ou restringir o acesso do agente e da ferramenta
- Revogar tokens, segredos, consentimento e sessões.
- Fontes, índices ou conectores de quarentena
- Reverter modelo, aviso, código ou política
- Preservar vestígios e conteúdo afetado
- Notificar os departamentos jurídico, de privacidade, de segurança, fornecedores e clientes, conforme necessário.

Recupere-se e aprenda

Restaure somente após compreender a causa e o escopo afetado. Valide os controles e execute testes de regressão antes de reabrir. Realize uma revisão imparcial que identifique melhorias técnicas, de processo e organizacionais.

- Confirme a integridade dos dados e do índice.
- Teste alterações de identidade e permissões
- Monitore atentamente após a restauração.
- Atualizar modelos de ameaças e manuais de estratégias
- Acompanhe as lições até a conclusão.

SEM IDENTIFICADOR DE TRANSAÇÃO COMUM

A equipe de segurança detecta um login suspeito, a equipe de operações observa um aumento repentino de custos e a equipe de desenvolvimento identifica chamadas de ferramentas incomuns. Sem um identificador de correlação compartilhado, os eventos não podem ser conectados rapidamente.

Prática: Realize um exercício de simulação de mesa.

- Escolha um cenário com RAG envenenado ou com agente comprometido.
- Identificar os primeiros sinais e os tomadores de decisão.
- Pratique o confinamento, a preservação de provas, a comunicação, a recuperação e a notificação.
- Registre os logs, permissões, contatos e procedimentos faltantes.

- Atribua as melhorias e agende um novo teste.

Verificação de controle do capítulo

- ☐ Uma transação pode ser rastreada através de identidade, aplicação, modelo, dados e ferramentas.
- ☐ O registro de dados sensíveis é minimizado e protegido.
- ☐ Existem manuais específicos para IA que são colocados em prática.
- ☐ A recuperação requer validação e testes de regressão.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 22 — Confiabilidade, Resiliência, Desempenho e FinOps

Garanta que os serviços de IA sejam confiáveis e acessíveis, evitando que interrupções, loops e uso indevido de recursos se transformem em incidentes de segurança.

Projetar para falhar

Modelos, provedores, regiões, redes, índices e ferramentas dependentes podem falhar ou ter sua capacidade limitada. Defina tempos limite, novas tentativas com recuo, disjuntores, filas, alternativas e procedimentos manuais. Garanta que uma solicitação repetida não possa duplicar uma ação de pagamento, exclusão ou emissão de ticket.

- Definir objetivos de tempo de recuperação e ponto de recuperação
- Use a idempotência para ações repetíveis
- Falha do provedor de testes e da região
- Defina degradação graciosa.
- Mantenha um modo de segurança que limite as ações autônomas.

Controle o consumo

Tokens, buscas, chamadas de ferramentas, armazenamento, avaliações e monitoramento geram custos. Ataques de negação de carteira e loops acidentais podem esgotar orçamentos ou cotas de serviço. Estabeleça limites nos níveis de usuário, agente, aplicativo, projeto e assinatura.

- Defina orçamentos e alertas
- Limites de taxa de uso, token, solicitação e simultaneidade
- Limitar as etapas do agente e as chamadas de ferramentas
- Armazene em local seguro, quando apropriado.
- Detectar gastos e usos incomuns
- Atribua a responsabilidade pelos custos com etiquetas e cobrança de custos.

Meça o desempenho sem enfraquecer os controles.

As melhorias de latência não devem ignorar autorização, filtragem, registro ou validação. Meça todo o fluxo do usuário e identifique etapas custosas ou lentas. Escolha modelos menores onde atendam aos requisitos e direcione as tarefas de acordo com o risco e a complexidade.

- Meça separadamente o tempo de recuperação, modelo, ferramenta e rede.
- Carga de teste e quotas
- Proteja os caches contra vazamento entre usuários.
- Incluir serviços de segurança nos testes de desempenho.
- Reavaliar custos e qualidade após alterações no modelo.

Utilize a perspectiva de uma arquitetura bem-feita.

Analise as cargas de trabalho de IA considerando confiabilidade, segurança, otimização de custos, excelência operacional e eficiência de desempenho. As compensações devem ser explícitas. Um projeto mais barato que comprometa a auditabilidade ou um projeto seguro que não permita recuperação ainda podem ser inaceitáveis.

- Documentar requisitos não funcionais
- Realizar avaliações de arquitetura
- Atribuir melhorias
- Repetir o teste após mudança significativa
- Registre as compensações aceitas e os proprietários

A TEMPESTADE DAS NOVAS TENTATIVAS

A API de uma ferramenta fica lenta. Centenas de agentes tentam novamente imediatamente, aumentando a carga e o custo até que a dependência falhe. Mecanismos de backoff, disjuntores, controle de filas e um loop de agentes limitado conteriam a falha.

Prática: Crie um plano de resiliência e custos.

- Identifique cinco dependências e como cada uma delas pode falhar.
- Defina o comportamento para tempo limite, nova tentativa, fallback e modo de segurança.
- Defina limites para usuários, agentes, aplicativos e assinaturas.
- Crie alertas de custo e confiabilidade.
- Planeje um teste de falha controlada.

Verificação de controle do capítulo

- ☐ As dependências e os modos de falha são documentados.
- ☐ Repetições, planos de contingência e ações repetidas são seguras.
- ☐ Existem limites de custo em vários níveis.
- ☐ Os controles de segurança permanecem ativos durante eventos de desempenho e recuperação.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 23 — IA Responsável, Supervisão Humana e Mudança Organizacional

Proteja as pessoas e as decisões empresariais através da criação de mecanismos de responsabilização, transparência, acessibilidade e controle humano efetivo.

Aplicar princípios de IA responsável

Equidade, confiabilidade e segurança, privacidade e proteção, inclusão, transparência e responsabilidade devem se tornar requisitos testáveis. Um princípio é útil quando altera decisões de projeto, dados, avaliação, implementação ou supervisão.

- Identificar as pessoas afetadas e os possíveis danos.
- Avaliar o desempenho em todos os grupos relevantes.
- Apresente limitações compreensíveis.
- Projetar interação acessível e alternativas
- Atribua responsáveis pela tomada de decisões
- Documente como as preocupações podem ser levantadas e corrigidas.

Dê significado à supervisão humana.

Uma etapa de revisão humana não é eficaz quando o revisor não dispõe de tempo, informações, autoridade ou uma forma realista de discordar. Defina quais decisões exigem revisão, quais evidências o revisor analisa, como a incerteza é demonstrada e como o revisor pode interromper ou reverter uma ação.

- Evite a aprovação automática.
- Apresentar fontes, intervalos de confiança e pressupostos relevantes.
- Treinar os revisores sobre as limitações do modelo.
- Registre as decisões e as alterações.
- Proteja os revisores da pressão da produção que compromete o controle.

Gerenciar o viés de automação

As pessoas costumam confiar em resultados automatizados confiáveis. Exija verificação para decisões legais, trabalhistas, de saúde, segurança, financeiras, de identidade e de proteção. Meça se os usuários detectam erros e forneça canais claros de escalonamento.

- Use uma linguagem calibrada em vez de falsas certezas.
- Exibir citações que os usuários possam abrir.
- Introduza atrito antes de ações consequentes.
- Resultados de amostra e revisão
- Forneça um caminho alternativo sem IA quando necessário.

Apoiar a adoção e a elaboração de relatórios.

Crie orientações simples, treinamento específico para cada função, exemplos aprovados, usos proibidos e um sistema fácil de notificação de incidentes. Incentive a comunicação precoce de erros sem tratar automaticamente todos os erros como má conduta.

- Ensine os usuários a proteger dados confidenciais.
- Explique como verificar o conteúdo gerado.
- Publicar serviços aprovados
- Forneça aos gerentes canais de escalonamento e tratamento de exceções.
- Utilize as lições aprendidas nos relatórios para aprimorar o design e o treinamento.

HUMANO NO CIRCUITO, APENAS NO NOME

Um revisor recebe centenas de aprovações geradas por IA a cada hora e não vê nenhuma evidência da origem. O sistema registra um clique humano, mas a pessoa não pode fornecer uma supervisão significativa.

Exercício: Elabore um controle de supervisão

- Escolha uma decisão consequente com o auxílio de IA.
- Defina o que a IA pode recomendar e o que ela jamais poderá decidir.
- Especifique as evidências e incertezas apresentadas ao revisor.
- Criar canais de exceção, apelação e escalonamento.
- Teste se um revisor consegue detectar três erros inseridos previamente.

Verificação de controle do capítulo

- ☐ Os princípios da IA responsável tornam-se requisitos mensuráveis.
- ☐ Os revisores humanos têm tempo, evidências, autoridade e alternativas.
- ☐ Os resultados de alto impacto são verificados de forma independente.
- ☐ Os usuários podem denunciar, corrigir, recorrer e escolher um caminho sem IA quando necessário.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 24 — Considerações Legais, Regulatórias, de Propriedade Intelectual e de Registros

Reconhecer quando as decisões de engenharia criam obrigações em matéria de privacidade, emprego, consumo, direitos autorais, contratos, setoriais ou registros.

Inclua a análise jurídica no processo de admissão.

Os requisitos variam de acordo com a jurisdição, o setor, os dados, as pessoas afetadas e o uso. Os engenheiros de segurança não devem fornecer aconselhamento jurídico, mas devem identificar os gatilhos precocemente e fornecer informações precisas sobre o sistema às equipes jurídicas e de privacidade.

- Dados pessoais e sensíveis
- Usos relacionados a emprego, crédito, seguros, saúde, educação, segurança e governo.
- Crianças e grupos vulneráveis
- Informações biométricas, de localização, de comunicação e comportamentais
- Processamento transfronteiriço e residência de dados
- Decisões automatizadas ou de alto impacto

Endereço de propriedade intelectual

Analise os direitos de treinamento, recuperação, avaliação e conteúdo gerado. Registre as licenças de modelos, código, conjuntos de dados, documentos, imagens e componentes de código aberto. Evite que os usuários presumam que a saída gerada seja automaticamente original, precisa ou segura para publicação.

- Respeite as licenças de código-fonte e de modelo.
- Controle da ingestão de material protegido por direitos autorais e confidencial.
- Forneça a citação e a atribuição quando necessário.
- Analise o código e o conteúdo gerados antes de usar.
- Estabeleça regras para conteúdo de clientes e funcionários.

Preserve registros e evidências.

Solicitações, respostas, aprovações, versões de modelos, avaliações e ações de agentes podem se tornar registros comerciais ou regulatórios. Coordene a retenção, as retenções legais, a descoberta eletrônica (eDiscovery), a privacidade, a investigação e a minimização. Manter tudo para sempre cria riscos; excluir tudo imediatamente destrói a responsabilidade.

- Classifique os registros por finalidade.
- Defina os critérios de retenção e acesso.
- Proteja as retenções legais.
- Manter a cadeia de custódia para investigações.
- Exclusão de documentos e exceções

Acompanhe as mudanças nos requisitos

Mantenha um registro regulatório e um responsável nomeado. Mapeie as obrigações aos controles e evidências, revise as alterações e evite alegar conformidade com base apenas em um recurso do fornecedor. Leis e normas podem ser aplicadas de forma diferente em cada região e para cada uso específico.

- Proprietário do registro de aplicabilidade e interpretação
- Acompanhar a implementação e as evidências.
- Revisar contratos e subcontratados
- Atualizar avaliações após alterações substanciais
- Comunique as limitações com honestidade.

Um conjunto de dados tecnicamente seguro, mas não autorizado.

Uma equipe protege um conjunto de dados de treinamento com criptografia e controle de acesso, mas nunca confirma se a organização tem o direito de usar os dados para o desenvolvimento do modelo. Os controles de segurança não criam permissão legal.

Exercício: Crie uma lista de gatilhos de requisitos

- Escolha um caso de uso de IA para suporte ao cliente.
- Identificar os dados, as pessoas, as jurisdições, as decisões, os contratos e os direitos de conteúdo envolvidos.
- Liste as perguntas para as equipes jurídicas, de privacidade, de registros e de compras.
- São necessárias evidências de engenharia cartográfica para respondê-las.
- Defina os eventos que exigem reavaliação.

Verificação de controle do capítulo

- ☐ A análise jurídica e de privacidade começa durante o processo de admissão.
- ☐ Os direitos de dados e conteúdo foram verificados.
- ☐ A retenção de registros busca o equilíbrio entre responsabilidade e minimização.
- ☐ As alegações de conformidade são sustentadas por controles e evidências aplicáveis.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 25 — Estruturas: NIST, ISO, MITRE e Mapeamento de Controles

Utilize estruturas complementares sem transformar a implementação em um mero exercício burocrático.

NIST AI RMF

A Estrutura de Gestão de Riscos de IA do NIST organiza o trabalho por meio de Governança, Mapeamento, Mensuração e Gestão. Utilize-a para estabelecer responsabilidades, compreender o contexto e os danos, avaliar riscos e implementar controles. O Perfil de IA Generativa adiciona riscos e ações específicos para IA generativa.

- Governança: políticas, funções, cultura, supervisão e responsabilidade.
- Mapa: contexto, usuários, impactos, dependências e riscos
- Medidas: testes, métricas, incerteza e monitoramento.
- Gerenciar: priorizar, responder, comunicar e melhorar.

Sistemas de gestão ISO e orientações sobre riscos

A norma ISO/IEC 42001 fornece uma estrutura para um sistema de gestão de IA. A ISO/IEC 27001 aborda a gestão da segurança da informação, a ISO/IEC 27701 a gestão da privacidade da informação e a ISO/IEC 23894 as diretrizes de risco em IA. Utilize normas oficiais e interpretação qualificada para trabalhos formais de conformidade ou certificação.

- Defina o escopo e as partes interessadas.
- Estabelecer políticas, objetivos, funções, competências e processos documentados.
- Avaliar riscos e impactos
- Operar controles e preservar evidências
- Auditar, corrigir, revisar e melhorar continuamente.

Cibersegurança e estruturas adversárias

O NIST CSF 2.0 organiza os resultados de cibersegurança em Governança, Identificação, Proteção, Detecção, Resposta e Recuperação. O NIST SP 800-53 oferece suporte à seleção detalhada de controles. O NIST SSDF e o SP 800-218A oferecem suporte ao desenvolvimento seguro. O MITRE ATLAS cataloga táticas e técnicas de IA adversárias.

- Utilize o CSF para os resultados do programa
- Utilize catálogos de controle para requisitos detalhados.
- Utilize o SSDF para o ciclo de vida de desenvolvimento.
- Use ATLAS e OWASP para ameaças e testes.
- Evite evidências duplicadas mapeando um controle para vários requisitos.

Construa uma faixa de pedestres útil.

Comece com os controles implementados e as evidências, depois mapeie-os para os resultados esperados da estrutura. Não crie controles separados para cada rótulo da estrutura quando um controle bem projetado atender a várias necessidades. Registre as lacunas e diferenças com honestidade.

- Objetivo e descrição do controle
- Proprietário e escopo
- Local de implementação
- Método e frequência de teste
- Evidências e retenção
- Requisitos mapeados
- Exceções e remediação

Em conformidade na planilha, fraco na produção.

Uma matriz de controle marca as revisões de acesso como concluídas porque existe uma política. As permissões da entidade de serviço nunca foram examinadas. O mapeamento da estrutura sem evidências operacionais gera uma falsa sensação de segurança.

Exercício: Mapeie um controle entre diferentes estruturas.

- Selecione a revisão trimestral das identidades dos agentes e das cargas de trabalho.
- Defina o objetivo, o escopo, o responsável, o método, as evidências e o tratamento de falhas.
- Mapeie para os resultados do NIST AI RMF, NIST CSF, ISO/IEC 42001, ISO/IEC 27001 e OWASP NHI.
- Identifique qualquer lacuna específica da estrutura.
- Crie um registro de teste.

Verificação de controle do capítulo

- ☐ Os frameworks são utilizados para a finalidade a que se destinam.
- ☐ Os mapeamentos apontam para a implementação real e para evidências concretas.
- ☐ Um único controle robusto pode dar suporte a diversas estruturas.
- ☐ A certificação formal baseia-se em normas oficiais e em avaliações qualificadas.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 26 — Construindo um Programa de Governança e Garantia de IA

Criar um sistema operacional para decisões de IA, inventários, aceitação de riscos, monitoramento, exceções e melhoria contínua.

Estabelecer governança

Crie um grupo multifuncional com representantes das áreas de negócios, tecnologia, segurança, privacidade, jurídico, compliance, risco, dados, compras, recursos humanos e segurança da informação, conforme apropriado. Defina as atribuições de decisão para que o grupo possibilite o uso responsável e oportuno dos dados, em vez de se tornar uma fila de revisões confusa.

- Aprovar a política e a classificação de risco.
- Defina usos proibidos e restritos.
- Defina as evidências e os pontos de liberação.
- Atribuir escalonamento e aceitação de risco
- Analisar incidentes, métricas, exceções e alterações importantes.

Manter um inventário de sistemas de IA

Inventário de IA desenvolvida internamente, adquirida, incorporada, experimental e paralela. Registro de finalidade, proprietário, usuários, pessoas afetadas, modelo, provedor, dados, agentes, NHIs (Número de Identificação Nacional de Saúde), integrações, região, nível de risco, aprovações, monitoramento, incidentes, data de revisão e status de desativação.

- Descubra através de sinais de aquisição, nuvem, identidade, rede, endpoint e dados.
- Conciliar o inventário com as fontes técnicas.
- Exigir registro antes da produção
- Analisar sistemas inativos e de alto risco
- Desative os registros somente após a remoção dos ativos conectados.

Utilize garantia por níveis de risco.

Projetos de baixo risco não devem exigir as mesmas evidências que um sistema autônomo que afeta o emprego ou a segurança. Defina níveis usando impacto, autonomia, sensibilidade dos dados, escala, exposição externa, reversibilidade e populações afetadas. Aumente a revisão e o monitoramento à medida que o risco aumenta.

- Critérios de nível de documento
- Defina controles mínimos por nível.
- Permitir escalonamento quando houver alto grau de incerteza.
- Exigir revisão independente para usos de alto impacto.

- Reavaliar após alteração substancial

Medir a saúde do programa

Utilize um conjunto equilibrado de indicadores: cobertura do inventário, tempo de revisão, ações em atraso, exceções de alto risco, descobertas de identidade, exposição de dados, falhas de avaliação, incidentes, tempo de contenção, alterações no modelo, treinamento, anomalias de custo e conclusão da desativação.

- Evite métricas que recompensem o ocultamento de incidentes.
- Relatar tendências e riscos materiais
- Conecte as descobertas aos responsáveis e aos prazos.
- Analise se os controles reduzem os danos.
- Melhorar as políticas e os padrões de engenharia com base em evidências.

O estoque contém apenas sistemas aprovados.

Os relatórios de governança oferecem cobertura completa, pois cada aplicativo registrado é analisado. Os dados de rede e de despesas revelam que os funcionários utilizam dezenas de serviços de IA não registrados. A qualidade do inventário deve ser comparada com as fontes de descoberta.

Exercício: Desenhe um fluxo de trabalho de governança

- Criar campos de entrada e critérios de classificação de risco.
- Defina os revisores, os direitos de decisão, os objetivos do serviço e o processo de escalonamento.
- Liste as evidências necessárias para risco baixo, médio e alto.
- Crie fluxos de trabalho para alterações, exceções, incidentes e desativações.
- Selecione dez métricas de programa que incentivem a divulgação honesta de informações.

Verificação de controle do capítulo

- ☐ Os direitos de decisão e a aceitação de riscos são claros.
- ☐ O inventário inclui IA adquirida, integrada, experimental e paralela.
- ☐ O esforço de garantia é proporcional ao risco.
- ☐ As métricas medem a abrangência, os resultados, a resposta e a melhoria.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

PARTE V — LABORATÓRIOS PRÁTICOS

Transformar conceitos em prática de engenharia repetível.

COMPREENDER • APLICAR • TESTAR • COMPROVAR

Capítulo 27 — Laboratórios de Engenharia de Segurança Guiada

Pratique todo o fluxo de trabalho em ambientes seguros e autorizados, utilizando dados de baixo risco e metas controladas.

Regras de laboratório

Utilize apenas recursos que você possui ou para os quais tem permissão explícita para testar. Comece com dados sintéticos. Defina orçamentos e datas de limpeza. Nunca execute testes automatizados em sistemas públicos ou de produção sem autorização por escrito, escopo aprovado, monitoramento e condições de parada.

- Objetivo do documento, responsável, escopo, contas a pagar, recursos e tráfego esperado.
- Crie instantâneos ou modelos reproduzíveis.
- Use identidades de teste separadas
- Proteger os resultados dos testes
- Limpar endpoints, índices, segredos, identidades, logs e dados.

Laboratórios da Fundação

Os primeiros laboratórios estabelecem uma estrutura segura de múltiplas contas da AWS, identidade, classificação de dados e registro de logs. Conclua-os antes do trabalho com agentes ou equipes vermelhas.

- Criar design de nomenclatura de ambiente e recursos
- Construa uma matriz de papéis de menor privilégio.
- Configure uma função do IAM e o acesso ao Secrets Manager ou ao AWS KMS.
- Projetar rotas de serviço privadas
- Envie logs do CloudTrail, CloudWatch, VPC Flow e logs de serviço para contas de segurança centralizadas.
- Criar alertas de orçamento e cota

laboratórios de aplicação de IA

Crie um pequeno assistente de políticas com documentos aprovados, citações, recuperação com reconhecimento de permissões, controles de conteúdo e solicitações rastreáveis. Adicione recursos um de cada vez e teste novamente após cada alteração.

- Implante ou selecione um modelo aprovado.
- Criar uma instrução de sistema versionada
- Construa um corpus RAG protegido
- Teste respostas e citações desconhecidas
- Adicionar uma ferramenta somente leitura restrita
- Criar uma identidade de agente e um loop delimitado

Laboratórios de garantia e operações

Teste a aplicação concluída usando modelagem de ameaças, casos OWASP, envenenamento RAG, revisão NHI, equipe vermelha, resposta a incidentes e mapeamento de framework.

- Executar conjuntos de dados de avaliação e regressão
- Exercício de injeção imediata direta e indireta
- Revisão de autorização e isolamento entre usuários
- Simule credenciais comprometidas e custos descontrolados.
- Realize uma simulação de incidente.
- Reúna um pacote de evidências de auditoria.

UM LABORATÓRIO SEM LIMPEZA

Um aluno conclui um exercício de agente seguro, mas deixa ativos uma implantação de modelo, um serviço de busca, um endpoint de teste público e um segredo de aplicação. A limpeza faz parte do laboratório, não é uma observação final opcional.

Exercício: Elabore o plano de laboratório.

- Indique o objetivo de aprendizagem e a autorização.
- Liste os recursos, identidades, dados, regiões, limites e custo previsto.
- Defina as condições de parada e o tratamento das evidências.
- Agendamento de limpeza e verificação.
- Peça a uma segunda pessoa para revisar os testes de alto impacto.

Verificação de controle do capítulo

- ☐ Os laboratórios utilizam alvos próprios ou explicitamente autorizados.
- ☐ Dados sintéticos ou de baixo risco são a opção padrão.
- ☐ São definidos os custos, o tráfego e as condições de parada.
- ☐ A limpeza inclui identidades, dados, índices, endpoints, segredos e logs.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

Capítulo 28 — Projeto Final: Agente de Conhecimento Empresarial Seguro

Reúna arquitetura, identidade, RAG (Raiz, Atitude e Gratidão), controles de agentes, testes, governança e operações em um projeto baseado em evidências.

Objetivo comercial

Projete um agente de conhecimento interno que responda a perguntas aprovadas sobre a política de cibersegurança, cite fontes, abra um chamado de serviço por meio de uma ferramenta específica e recuse solicitações não suportadas ou não autorizadas. Utilize documentos sintéticos que representem classificações públicas, internas e restritas.

- Defina os usuários pretendidos e os usos proibidos.
- Defina resultados mensuráveis em termos de qualidade, segurança, privacidade, proteção, confiabilidade e custo.
- Atribua os responsáveis pelas áreas de negócios, dados, engenharia, segurança, privacidade e operações.
- Classifique o caso de uso e obtenha aprovação.

Arquitetura e construção

Crie projetos de desenvolvimento e produção separados usando Amazon Bedrock ou SageMaker AI, um modelo aprovado, bases de conhecimento Bedrock ou OpenSearch, Amazon S3, funções IAM, Secrets Manager e KMS, API Gateway, Macie e DataZone, Security Hub, GuardDuty e monitoramento centralizado. Preserve as permissões de documentos durante a recuperação.

- Desenhe fluxos de dados e controle
- limites de confiança do modelo de ameaça
- Use identidades gerenciadas
- Restringir a rede e a saída
- Código da versão, prompts, dados, índice, avaliação e implantação.
- Exigir confirmação humana antes do envio do ticket caso haja alteração no serviço ou no acesso solicitado.

Garantia

Avalie perguntas comuns, perguntas desconhecidas, fontes conflitantes, conteúdo desatualizado, inserção direta e indireta de prompts, divulgação de informações sensíveis, recuperação de dados entre usuários, uso indevido de ferramentas, solicitações excessivas, conteúdo prejudicial e falhas do provedor. Converta as descobertas confirmadas em testes de regressão.

- Definir falhas que bloqueiam a liberação
- Realizar revisão por pares e equipe vermelha autorizada

- Analisar os Seguros Nacionais de Saúde (NHIs) e seus segredos.
 - Confirme o registro de logs e os manuais de incidentes.
1. Registrar o risco residual e a aceitação.

Operações e evidências

Crie painéis de controle, alertas, orçamentos, revisões de acesso, cronogramas de avaliação, pontos de controle de mudanças, manuais de incidentes, procedimentos de backup e contingência e etapas de desativação. Elabore um pacote que outro engenheiro ou auditor possa seguir sem explicações verbais.

- Arquitetura e modelo de ameaças
- Inventário de IA e lista de materiais
- Registros de dados e identidades
- Relatórios de avaliação e de equipe vermelha
- Matriz de controle e aprovações
- Procedimentos operacionais, de incidentes, de recuperação e de desativação

A DECISÃO DE LIBERAÇÃO DO CAPSTONE

O agente atende às metas de qualidade e custo, mas falha em um teste de autorização entre usuários. A decisão correta é bloquear a liberação, corrigir o projeto de filtragem, executar novamente o conjunto completo de testes relevantes e documentar o resultado.

Prática: Conclua o projeto final.

- Criar o termo de abertura e a arquitetura do projeto.
- Construa o sistema mínimo funcional.
- Implementar controles de identidade, dados, rede, aplicação, modelo e monitoramento.
- Realizar avaliações, exercícios de equipe vermelha, resiliência e incidentes.
- Apresentar evidências, risco residual e recomendação de liberação.

Verificação de controle do capítulo

- ☐ A pedra angular é útil, delimitada, autorizada e mensurável.
- ☐ As permissões são aplicadas antes da recuperação e da execução da ferramenta.
- ☐ Falhas críticas bloqueiam a liberação.
- ☐ As evidências comprovam a viabilidade das etapas de construção, teste, operação, resposta e desativação.

EVIDÊNCIAS A SEREM GUARDADAS

Atualizações de arquitetura ou fluxo de dados, evidências de configuração ou política, resultados de testes, constatações e soluções, aprovações, exceções e a data e o responsável pela próxima revisão.

APÊNDICES

Listas de verificação reutilizáveis, modelos, glossário e fontes oficiais de aprendizagem.

COMPREENDER • APLICAR • TESTAR • COMPROVAR

Apêndice A — Lista de Verificação de Preparação para Produção

Finalidade e propriedade

- ☐ Finalidade aprovada e usos proibidos
- ☐ Proprietários de negócios, dados, engenharia, segurança, privacidade e operações
- ☐ Nível de risco e autoridade de aceitação
- ☐ Supervisão humana e via de recurso

Arquitetura e identidade

- ☐ Diagrama atual de fluxo de dados e limites de confiança
- ☐ Identidades de usuário, carga de trabalho e agente com privilégios mínimos
- ☐ Identidade gerenciada ou federação, quando viável.
- ☐ Controles de rede privada e de saída
- ☐ Secrets Manager, KMS e evidências de rotação

Dados e RAG

- ☐ Fontes aprovadas, classificações, permissões, linhagem e retenção.
- ☐ Filtragem de permissões antes da recuperação
- ☐ Testes de envenenamento e injeção indireta
- ☐ Teste de exclusão de dados derivados
- ☐ Comportamento de citação e resposta desconhecida

Agentes e ferramentas

- ☐ Inventário aprovado de agentes, servidores MCP, conectores e ferramentas.
- ☐ Objetivos, etapas, tempo, custo, destinos e transações definidos.
- ☐ Validação da entrada e saída da ferramenta
- ☐ Aprovação humana para ações consequentes
- ☐ Procedimento de desativação de emergência

Garantia e operações

- ☐ Avaliações de qualidade, segurança, proteção, privacidade, confiabilidade e custo.
- ☐ Relatório e remediação autorizados pela equipe vermelha
- ☐ Registros e alertas de ponta a ponta
- ☐ Manuais de incidentes, interrupções, custos e provedores

☐ Testes de reversão, fallback, recuperação e aposentadoria

Apêndice B — Modelo de entrada de casos de uso de IA

Nome do caso de uso e objetivo comercial

Resposta: _____

Patrocinador executivo e proprietário da empresa

Resposta: _____

Usuários pretendidos e pessoas afetadas

Resposta: _____

Usos pretendidos e proibidos

Resposta: _____

Decisões ou ações apoiadas

Resposta: _____

Modelos, fornecedores, regiões e rota de implantação

Resposta: _____

Fontes de dados, classificações, proprietários e finalidade permitida

Resposta: _____

RAG, memória, agentes, servidores MCP, ferramentas e conexões externas.

Resposta: _____

Supervisão humana, apelação, correção e alternativa sem IA

Resposta: _____

Danos potenciais e maior impacto provável

Resposta: _____

Análises legais, de privacidade, de registros, contratuais e setoriais.

Resposta: _____

Medidas de qualidade, segurança, proteção, privacidade, confiabilidade e custo

Resposta: _____

Nível de risco, revisores necessários, aprovação e data da próxima revisão.

Resposta: _____

Apêndice C — Campos do Sistema de IA e do Inventário do NHI

Inventário de sistemas de IA

- ID do sistema, nome, descrição e status.
- Proprietário da empresa, proprietário técnico, proprietário dos dados e patrocinador.
- Usuários, pessoas afetadas, escala e geografia.
- Nível de risco e histórico de aprovação
- Modelos, fornecedores, versões, rota de implantação e região.
- Fontes de dados, classificação, retenção e exclusão
- RAG, memória, agentes, ferramentas, MCP, APIs e conectores
- Arquitetura de segurança, monitoramento, incidentes, exceções e próxima revisão.
- Data de aposentadoria e confirmação da remoção de recursos.

Inventário de identidade não humana

- Identidade (ID), tipo, locatário, ambiente e método de criação
- Proprietário, patrocinador, propósito e sistema dependente
- Funções, escopos de API, recursos e autoridade delegada.
- Tipo de credencial, localização, rotação e validade
- Último login, atividade recente, eventos de risco e data de revisão.
- Gatilho para desativação, método de desativação e contato de emergência

Apêndice D — Modelo de Risco e Resultados

- Título
- Sistema e componente afetado
- Cenário e pré-condições
- Ameaça ou fracasso
- Fraqueza ou lacuna de controle
- Impacto nos negócios, na área técnica, na privacidade ou na segurança
- Etapas de evidência e reprodução
- Classificação de probabilidade e impacto
- Requisitos aplicáveis da OWASP, MITRE, NIST, ISO ou internos.
- Ação recomendada e controles compensatórios
- Proprietário, data de vencimento e status
- Resultado do reteste
- Autoridade de aceitação e risco residual

DICA DE ESCRITA

Descreva o que foi observado, o que foi inferido e o que poderia acontecer como ideias separadas. Resultados claros são mais fáceis de verificar e de aplicar.

Apêndice E — Glossário

Prazo	Significado
Agente	Software que utiliza um modelo para planejar ou selecionar ações, geralmente por meio de ferramentas ou outros serviços.
Identidade do agente	Uma identidade governada que representa um agente de IA e seu acesso permitido.
lista de materiais de IA	Um inventário de modelos, dados, código, instruções, ferramentas, serviços e dependências usados por um sistema de IA.
sistema de IA	A combinação completa de modelo, aplicação, dados, pessoas, processos, identidades, ferramentas e infraestrutura.
API	Uma interface definida que permite que serviços de software troquem solicitações e resultados.
Autenticação	O processo de comprovar uma identidade.
Autorização	A decisão sobre o que uma identidade autenticada pode fazer.
Pedaço	Uma parte de um documento preparada para pesquisa, incorporação ou recuperação.
Confidencialidade	Proteção contra divulgação não autorizada.
Filtro de conteúdo	Um controle que detecta ou bloqueia categorias configuradas de entrada ou saída.
Janela de contexto	A quantidade limitada de instruções e informações disponíveis para um modelo durante uma solicitação.
Controlar	Uma medida de segurança que altera a probabilidade ou o impacto do risco.
Linhagem de dados	Um registro da origem dos dados, como eles mudaram e para onde foram transferidos.
Envenenamento de dados	Manipulação de dados de treinamento, avaliação, recuperação ou outros para influenciar o comportamento do sistema.

Prazo	Significado
Incorporação	Uma representação numérica usada para comparar significado ou semelhança.
Afinação	Treinamento adicional do modelo é usado para ajustar o comportamento a exemplos ou tarefas.
Firmeza	O grau em que uma resposta é sustentada pelas informações da fonte fornecida.
Guarda-corpo	Uma política, filtro, limite, validação, aprovação ou outra restrição ao comportamento do sistema.
Alucinação	Conteúdo gerado que parece plausível, mas não possui respaldo ou está incorreto.
Supervisão humana	Capacidade humana significativa de revisar, interromper, corrigir ou reverter uma ação assistida por IA.
Inferência	Utilizando um modelo treinado para produzir um resultado.
Integridade	Proteção contra alterações não autorizadas ou indevidas.
Privilégios mínimos	Fornecer apenas o acesso necessário para uma tarefa e período de tempo definidos.
Mestrado em Direito	Um modelo de linguagem de grande porte treinado para processar e gerar linguagem.
LLMOps	Práticas para versionamento, lançamento, monitoramento e desativação de aplicações baseadas em modelos de linguagem.
Identidade gerenciada	Uma identidade gerenciada pelo Azure que os aplicativos podem usar sem armazenar credenciais comuns.
MCP	O Protocolo de Contexto de Modelo (Model Context Protocol) é um padrão usado para conectar aplicações de modelos com ferramentas e contexto.
Filtragem de metadados	Utilizando atributos como usuário, locatário, classificação ou origem para restringir a recuperação de dados.

Prazo	Significado
Cartão modelo	Uma descrição do uso pretendido de um modelo, sua avaliação, limitações e outras informações importantes.
Identidade não humana	Uma identidade usada por software, automação, cargas de trabalho, agentes ou dispositivos, em vez de uma pessoa.
Incitar	Texto ou outra entrada fornecida para orientar a resposta do modelo.
injeção imediata	Entrada que tenta alterar o comportamento do modelo ou substituir as instruções pretendidas.
TRAPO	Geração aumentada por recuperação, que fornece informações recuperadas a um modelo no momento da solicitação.
Equipe vermelha	Testes autorizados que simulam uso indevido, ataque ou falha na identificação de riscos.
risco residual	Risco remanescente mesmo após a aplicação dos controles.
Responsável pelo risco	A pessoa responsável pelo objetivo de negócio afetado e pela decisão de risco.
aparar segurança	Filtrar resultados de pesquisa ou recuperação para que uma identidade receba apenas conteúdo autorizado.
Principal do serviço	Uma identidade usada por um aplicativo ou serviço no Microsoft Entra ID.
IA Sombra	Serviços ou recursos de IA utilizados sem a aprovação ou visibilidade organizacional necessárias.
Instruções do sistema	Orientações fornecidas pela aplicação destinadas a moldar o comportamento do modelo.
Token	Uma unidade de texto processada por um modelo de linguagem.
Ferramenta de chamada	Uma aplicação modelo é uma solicitação estruturada para que um software externo execute uma operação.
Limite de confiança	Um ponto onde os dados ou o controle cruzam diferentes níveis de confiança ou autoridade.

Prazo	Significado
Banco de dados vetorial	Um serviço que armazena e pesquisa embeddings e metadados associados.
Identidade da carga de trabalho	Uma identidade usada por um aplicativo, serviço, contêiner ou carga de trabalho de automação.
Confiança Zero	Uma abordagem de segurança baseada em verificação explícita, privilégio mínimo e comprometimento presumido.

Apêndice F — Fontes Oficiais e Aprendizagem Contínua

Utilize fontes oficiais atualizadas ao implementar controles ou tomar decisões de conformidade. As páginas de produtos, normas, leis, funcionalidades e disponibilidade de modelos estão sujeitas a alterações.

PRINCÍPIO DE FECHAMENTO

Um bom engenheiro de segurança mantém-se curioso, verifica hipóteses, documenta evidências, protege as pessoas e aprimora o sistema após cada mudança e aprendizado.

[Documentação do Amazon Bedrock](#)

[Documentação do Amazon SageMaker AI](#)

[Arquitetura de referência de segurança da AWS para IA](#)

[Documentação do AWS Identity and Access Management](#)

[Documentação do IAM Identity Center](#)

[AWS Security Hub CSPM e GuardDuty](#)

[AWS Well-Architected Generative AI Lens](#)

[Amazon Bedrock Guardrails](#)

[AWS Responsible AI Lens](#)

[OWASP Top 10 para candidaturas a mestrado em Direito \(LLM\)](#)

[OWASP Top 10 para Aplicações Agentes](#)

[OWASP Top 10 de Identidades Não Humanas](#)

[Segurança da API OWASP](#)

[ATLAS MITRE](#)

[Estrutura de Gestão de Riscos de IA do NIST](#)

[Perfil de IA Generativa do NIST](#)

[Estrutura de Desenvolvimento de Software Seguro do NIST](#)

[Estrutura de cibersegurança do NIST](#)

[Documentação da API OpenAI](#)

[Pesquisa de arquivos OpenAI](#)

[Documentação Claude Antrópico](#)

[Visão geral da norma ISO/IEC 42001](#)

Registro de manutenção

Revise este manual pelo menos a cada seis meses e após alterações significativas no Amazon Bedrock, SageMaker AI, IAM, Macie ou Security Hub, provedores de modelos, diretrizes da OWASP, publicações do NIST ou legislação aplicável. Registre correções e notas de versão no repositório de publicações.